

مقدمه‌ای بر مدیریت عملیات تیم قرمز

مجموعه کتاب های تیم قرمز

تهیه و تنظیم : تیم سایبر شلف



@CYBERSHELF



فهرست مطالب

۱.....	مقدمه نویسنده
۳.....	در این کتاب چه می‌خوانیم
۴.....	فصل اول حکمرانی استراتژیک تیم قرمز
۵.....	۱,۱ - مقدمه‌ای بر تیم قرمز (Red Teaming)
۵.....	هدف:
۵.....	۱. تعریف و هدف تیم قرمز
۵.....	۲. تفاوت تیم قرمز با تست نفوذ
۶.....	۳. تیم قرمز در بستر شبیه‌سازی مهاجم (Adversary Emulation)
۶.....	۴. خروجی‌ها و ارزش برای سازمان
۷.....	۱,۲ - اهداف تیم قرمز و ارزش آن برای سازمان
۷.....	هدف:
۷.....	۱. اهداف اصلی عملیات تیم قرمز
۷.....	۲. مزایای راهبردی برای سازمان
۸.....	۳. شاخص‌های سنجش و ارزیابی
۸.....	۴. محدودیت‌ها و ملاحظات
۹.....	۱,۳ - حاکمیت عملیاتی و مدل‌های تعامل تیم قرمز
۹.....	هدف:
۹.....	۱. اصول حاکمیت تیم قرمز
۹.....	۲. مدل‌های اصلی تعامل (Engagement Models)
۱۰.....	۳. نقش‌ها و مسئولیت‌های سازمانی
۱۰.....	۴. الزامات قانونی، اخلاقی و انطباقی
۱۲.....	۱,۴ - محدوده بندی مأموریت (Engagement Scoping)

هدف:	۱۲
۱. هدف از محدوده بندی	۱۲
۲. ابعاد کلیدی محدوده بندی	۱۲
۳. دسته‌بندی ریسک و همسویی با کسب‌وکار	۱۳
۴. تعامل و تأیید ذی‌نفعان	۱۳
۵. اسناد و مدارک محدوده بندی	۱۴
فصل دوم برنامه‌ریزی و اجرای عملیات تهاجمی	۱۵
۲,۱ - فازهای برنامه‌ریزی	۱۶
هدف:	۱۶
۱. برنامه‌ریزی به‌عنوان یک عملکرد راهبردی	۱۶
۲. مراحل چرخه عمر برنامه‌ریزی	۱۶
۳. بهترین شیوه‌های برنامه‌ریزی	۱۸
۴. خروجی‌های فاز برنامه‌ریزی	۱۸
۲,۲ - راه‌اندازی زیرساخت	۱۹
هدف:	۱۹
۱. هدف از زیرساخت تیم قرمز	۱۹
۲. اجزای زیرساخت و معماری	۱۹
۳. ملاحظات OPSEC در زیرساخت	۲۰
۴. استقرار و تست	۲۰
۵. نمونه ابزارهای زیرساخت تیم قرمز	۲۱
۶. مستندسازی و تحویل	۲۱
۲,۳ - جریان کاری اجرای عملیات	۲۲
۱. نمای کلی از جریان اجرای عملیات	۲۲

۲۲.....	۲. مراحل اجرای عملیات
۲۴.....	۳. تدابیر ایمنی عملیاتی
۲۴.....	۴. شاخص‌های قابل پیگیری در طول اجرا
۲۵.....	۵. انضباط و واقع‌گرایی عملیاتی
۲۶.....	۲,۴ - رفع تداخل (Deconfliction) و ایمنی عملیاتی
۲۶.....	هدف:
۲۶.....	۱. چرا رفع تداخل و ایمنی اهمیت دارند
۲۶.....	۲. مکانیزم‌های رفع تداخل
۲۷.....	۳. کنترل‌های ایمنی
۲۸.....	۴. واکنش به ریسک در زمان واقعی
۲۸.....	۵. اعتبارسنجی پس از عملیات
۲۹.....	۲,۵ - شاخص‌ها و پایش مستمر در طول اجرای عملیات
۲۹.....	هدف:
۲۹.....	۱. اهمیت پایش بلادرنگ
۲۹.....	۲. دسته‌بندی شاخص‌ها برای پیگیری
۳۱.....	۳. ابزارها و تکنیک‌های پایش
۳۱.....	۴. ارزیابی و سازگاری مستمر (Continuous Assessment and Adaptation)
۳۲.....	۵. مستندسازی و یکپارچگی گزارش دهی
۳۳.....	فصل سوم هماهنگی پس از اجرای عملیات
۳۴.....	۳,۱ - گزارش دهی عملیاتی
۳۴.....	هدف:
۳۴.....	۱. هدف از گزارش دهی تیم قرمز
۳۴.....	۲. انواع گزارش‌های تیم قرمز

۳. مصنوعات پشتیبان (Supporting Artifacts) ۳۵
۴. تحویل و ارائه ۳۵
۵. بهترین شیوه‌های گزارش دهی پس از تعامل ۳۶
- ۳,۲ – یکپارچه‌سازی تیم بنفش و تطبیق با مقررات (DORA و TIBER-EU) ۳۷
- هدف: ۳۷
۱. تیم بنفش چیست؟ ۳۷
۲. جریان یکپارچه‌سازی پس از تعامل تیم قرمز ۳۷
۳. تطبیق با الزامات TIBER-EU ۳۸
۴. نگاشت به الزامات DORA ۳۸
۵. توصیه‌های برنامه‌ریزی تیم بنفش ۳۹
۶. ابزارهای تمرین تیم بنفش ۳۹
۷. خلاصه مزایای مقرراتی و عملیاتی ۴۰
- ۳,۳ – معیارها و بهبود مستمر ۴۱
۱. نقش معیارها در دفاع مبتنی بر تهدید ۴۱
۲. معیارهای عملکرد رایج تیم قرمز ۴۱
۳. نگاشت معیارها به چارچوب‌ها ۴۲
۴. حلقه بهبود مستمر (Continuous Improvement Loop) ۴۲
۵. گزارش دهی استراتژیک و معیارهای اجرایی ۴۳
۶. یکپارچه‌سازی در استراتژی تاب‌آوری سایبری ۴۳
- ۳,۴ – توسعه برنامه تیم قرمز ۴۴
۱. انتقال از پروژه به برنامه ۴۴
۲. اجزای اصلی برنامه بلوغ تیم قرمز ۴۴
۳. مدل بلوغ تیم قرمز ۴۵

۴۶.....	۴. یکپارچه‌سازی میان واحدها و تیم‌ها
۴۶.....	۵. یادگیری مستمر و پیگیری تهدیدات
۴۶.....	۶. اندازه‌گیری اثربخشی برنامه
۴۷.....	۷. گسترش تلاش‌های تیم قرمز (Scaling Red Team Efforts)
۴۸.....	فصل چهارم یکپارچه‌سازی عملیاتی و استراتژی آینده‌نگر
۴۹.....	۴,۱ - تیم قرمز به‌عنوان یک کارکرد راهبردی امنیتی
۴۹.....	هدف:
۴۹.....	۱. تکامل نقش تیم قرمز
۴۹.....	۲. هم‌راستایی راهبردی با ریسک سازمانی
۵۰.....	۳. تأثیر بر معماری و مهندسی امنیت
۵۰.....	۴. خروجی‌های راهبردی برای گزارش دهی
۵۰.....	۵. شاخص‌های کلیدی عملکرد (KPIs) و شاخص‌های راهبردی
۵۱.....	۶. حفظ نفوذ راهبردی
۵۲.....	۴,۲ - عملیاتی‌سازی یافته‌ها در سراسر سازمان
۵۲.....	هدف
۵۲.....	۱. از گزارش تا پاسخ
۵۲.....	۲. ادغام در چارچوب‌های کنترلی
۵۳.....	۳. هماهنگی میان تیم‌ها و برنامه‌ریزی اصلاحی
۵۳.....	۴. نهادینه‌سازی درس‌های آموخته‌شده
۵۳.....	۵. خودکارسازی و ادغام با ابزارها
۵۴.....	۶. ساخت «حافظه عضلانی سازمانی»
۵۴.....	۷. نظارت اجرایی و شفافیت
۵۵.....	۴,۳ - آمادگی مداوم برای رعایت مقررات

هدف: ۵۵.....

۱. تغییر جهت به سمت رعایت مداوم مقررات ۵۵.....

۲. چارچوب‌های نظارتی که نیازمند یا پشتیبان تیم قرمز هستند ۵۵.....

۳. خروجی‌های تیم قرمز که رعایت مقررات را تسهیل می‌کنند ۵۶.....

۴. ریتم کاری تیم قرمز و یکپارچه‌سازی با الزامات قانونی و مدیریتی ۵۶.....

۵. ردیابی و پشتیبانی از حسابرسی ۵۷.....

۶. تیم قرمز به‌عنوان تسهیل‌کننده رعایت مقررات ۵۷.....

۴,۴ - تیم قرمز در محیط‌های ابری و ترکیبی ۵۸.....

هدف: ۵۸.....

۱. سطح حمله مدرن ۵۸.....

۲. درک چشم‌انداز تهدید ابری ۵۸.....

۳. حوزه‌های تمرکز تیم قرمز در ابری ۵۹.....

۴. ابزارها و چارچوب‌های شبیه‌سازی ابری ۵۹.....

۵. ملاحظات عملیاتی امنیتی ابری (OPSEC) ۶۰.....

۶. همسویی با رعایت مقررات و مدیریت ریسک ۶۰.....

۷. ادغام TTP-های ابری در برنامه‌های تیم قرمز ۶۱.....

۴,۵ - شناسایی و دنبال کردن روندهای تهدید آینده و اجرای عملیات تیم قرمز به‌صورت تطبیقی و

پویا ۶۲.....

هدف: ۶۲.....

۱. نیاز به تطبیق‌پذیری در تیم قرمز ۶۲.....

۲. وکتورهای تهدید و روندهای نوظهور ۶۲.....

۳. روش‌شناسی تیم قرمز پویا و پاسخگو به تهدیدها ۶۳.....

۴. خودکارسازی و هوش مصنوعی در عملیات تیم قرمز ۶۴.....

۵. آماده‌سازی برای آزمون تاب‌آوری پساکوانتومی و رمزنگاری ۶۴
۶. مهارت‌ها و ساختار تیم قرمز آینده ۶۴
۷. یکپارچگی استراتژیک با برنامه‌ریزی تاب‌آوری ۶۵
- ۴,۶ - تعبیه تاب‌آوری تیم قرمز در عملیات روزمره سازمان ۶۶
- هدف ۶۶
۱. از پروژه‌های جداگانه به قابلیت‌های درونی ۶۶
۲. نقاط یکپارچه‌سازی در سراسر سازمان ۶۶
۳. ایجاد تیم‌بندی پیوسته (Continuous Purple Teaming) ۶۷
۴. استفاده مجدد از کتابچه‌های عملیاتی و نگهداری دانش ۶۷
۵. شاخص‌های اندازه‌گیری تاب‌آوری داخلی ۶۸
۶. ایجاد عملیات تیم قرمز قابل تکرار و مقیاس‌پذیر ۶۸
۷. دستاوردهای راهبردی ۶۸
- فصل پنجم جمع‌بندی نهایی، ارزیابی و تبدیل به عملیات ۶۹
- ۵,۱ - سناریوی پایانی: برنامه‌ریزی کامل تیم قرمز ۷۰
- هدف ۷۰
۱. مروری بر سناریوی پایانی ۷۰
۲. پارامترهای سناریو ۷۰
۳. اجزای ضروری برنامه ۷۰
۴. راهنمای ارزیابی ۷۲
۵. اختیاری: اجرای تیمی ۷۲
- ۵,۲ - نقشه راه بلوغ مبتنی بر تهدید ۷۳
- هدف ۷۳
۱. چرا نقشه راه بلوغ ضروری است؟ ۷۳

۲. مدل بلوغ پایه‌ای تیم قرمز ۷۳
۳. ورودی‌های لازم برای برنامه‌ریزی نقشه راه ۷۴
۴. ساختاردهی نقشه راه ۷۵
۵. ابزارهای ردیابی بلوغ ۷۶
۶. حاکمیت و همسویی با بودجه ۷۶
۷. جمع‌بندی ۷۶
- ۵,۳ - نهادینه‌سازی بازخورد و درس‌های آموخته‌شده ۷۷
- هدف ۷۷
۱. چرا بازخورد باید نهادینه شود؟ ۷۷
۲. ایجاد چارچوب درس‌های آموخته‌شده ۷۷
۳. دسته‌بندی بازخوردها ۷۸
۴. انتقال بازخورد به سیستم‌های سازمانی ۷۸
۵. ابزارها و فرآیندهای نگهداری بازخورد ۷۸
۶. شاخص‌ها برای سنجش یادگیری نهادی ۷۹
۷. جاسازی درس‌ها در فرهنگ سازمانی ۸۰
- ۵,۴ - اعتبارسنجی برنامه و آمادگی برای ممیزی ۸۱
- هدف ۸۱
۱. چرا تیم قرمز باید اعتبارسنجی و مستندسازی شود؟ ۸۱
۲. اسناد کلیدی موردنیاز ۸۱
۳. الزامات نظارتی که تیم قرمز می‌تواند پوشش دهد ۸۲
۴. آماده‌سازی برای ممیزی‌های داخلی و خارجی ۸۲
۵. بازبینی راهبری تیم قرمز ۸۳
۶. شواهد بهبود مستمر ۸۳

۷. جعبه‌ابزار آمادگی برای پاسخ به ممیزی	۸۳
۵,۵ - امنیت عملیاتی (OpSec) برای تیم قرمز در بلندمدت	۸۵
هدف:	۸۵
۱. نقش OpSec در تیم قرمز	۸۵
۲. ستون‌های اصلی OpSec در تیم قرمز	۸۶
۳. طراحی زیرساخت و ایزولاسیون	۸۶
۴. حفاظت از payload-ها و ایمپلنت‌ها (Implants)	۸۷
۵. مدیریت هویت و ساختن هویت پوششی (Persona)	۸۷
۶. OpSec تدافعی: جلوگیری از شناسایی زود هنگام	۸۸
۷. پاک‌سازی پس از پایان عملیات (Post-Engagement Sanitization)	۸۸
۸. ابزارها و تکنیک‌هایی که از OpSec پشتیبانی می‌کنند	۸۹
خلاصه و نتیجه‌گیری	۸۹
۵,۶ - ارزیابی نهایی: ارائه استراتژی یا دفاع از سناریو	۹۰
هدف:	۹۰
۱. هدف از ارزیابی نهایی	۹۰
۲. قالب‌های ارزیابی	۹۰
۳. معیارهای ارزیابی	۹۰
۴. نقش‌های شبیه‌سازی شده ذی‌نفعان (اختیاری برای ارائه زنده)	۹۱
۵. روش‌های ارائه و تحویل خروجی‌ها	۹۱
۶. بازخورد و امتیازدهی	۹۲
۷. نتیجه	۹۲
نتیجه‌گیری	۹۳

مقدمه نویسنده

به کتاب «مقدمه‌ای بر مدیریت عملیات تیم قرمز» - برنامه‌ریزی، اجرا و هماهنگی عملیات تهاجمی با تمرکز بر نتایج واقعی - خوش آمدید.

این کتاب، حاصل تجربه و مطالعات عملی در زمینه امنیت سایبری و مدیریت عملیات پیشرفته است. هدف آن ارائه چارچوبی ساختارمند برای متخصصان امنیت، رهبران فنی و کارشناسان حاکمیت است تا توانمندی‌های تیم قرمز را در محیط‌های سازمانی و تحت نظارت مقررات ایجاد یا ارتقا دهند.

در طول پنج فصل این کتاب، شما با دانش و ابزارهایی آشنا خواهید شد که توانمندی شما در طراحی، اجرای و نهادینه‌سازی کمپین‌های تیم قرمز را به سطحی فراتر از بهره‌برداری صرف فنی می‌برد. شما یاد خواهید گرفت چگونه کمپین‌ها را بر اساس چارچوب MITRE ATT&CK و تهدیدات خاص صنعت خود طراحی کنید، الزامات قانونی و تطابق با استانداردها مانند TIBER-EU و DORA را در برنامه‌ریزی و گزارش دهی رعایت کنید و عملیات را با اصول امنیت عملیاتی (OPSEC)، قوانین درگیری (RoE) و مدیریت چرخه عمر زیرساخت‌ها هماهنگ سازید.

علاوه بر این، اجرای شبیه‌سازی‌های پیشرفته در محیط‌های ابری و ترکیبی، عملیاتی سازی یافته‌ها به شکل بهبودهای کاربردی در تیم‌های SOC، IR، GRC و مهندسی و ایجاد و ارزیابی بلوغ تیم قرمز از طریق نقشه راه و مدل‌های توانمندی، از دیگر مفاهیمی است که در این کتاب به آن پرداخته می‌شود.

خوانندگان این کتاب با طراحی و دفاع از یک برنامه جامع کمپین تیم قرمز در قالب سناریوی نهایی، تجربه عملی و دانش لازم برای همسوسازی شبیه‌سازی مهاجم با ریسک تجاری، عمق فنی و الزامات قانونی را کسب خواهند کرد.

چه در حال راه‌اندازی یک تیم قرمز جدید باشید، چه بخواهید نقش راهبردی آن را تقویت کنید یا آزمون‌ها را با الزامات مدیریتی و انطباقی هماهنگ سازید، این کتاب چارچوب‌ها، رویکردها و تاکتیک‌های لازم برای موفقیت شما را در اختیار خواهد گذاشت.

نکته‌ای که مایلیم با شفافیت بیان کنم این است که بخش مهمی از محتوای کتاب با کمک یک مدل زبان بزرگ (LLM) آماده و سپس بازبینی و تکمیل شده است؛ موضوعی که فرصتی برای سرعت بخشیدن به تولید محتوا فراهم کرد و نشان می‌دهد چگونه می‌توان از فناوری‌های نوین در خدمت یادگیری بهره گرفت.

مقدمه‌ای بر مدیریت عملیات تیم قرمز

امیدوارم مطالعه این کتاب برای شما الهام‌بخش باشد و در مسیر حرفه‌ای‌تان در حوزه امنیت تهاجمی، دیدگاهی تازه و مهارت‌هایی عملی به ارمغان بیاورد.

با احترام،

تیم سایبر شلف

t.me/cybershelf

در این کتاب چه می‌خوانیم

این کتاب برای متخصصان امنیت سایبری، رهبران فنی و کارشناسان حاکمیت طراحی شده است که قصد دارند توانمندی‌های تیم قرمز را در محیط‌های سازمانی یا تحت نظارت مقررات، ایجاد یا مدیریت کنند.

مدیریت عملیات تیم قرمز فراتر از بهره‌برداری فنی عمل کرده و رویکردی جامع و مبتنی بر تهدید ارائه می‌دهد که شامل برنامه‌ریزی، اجرا و نهادینه‌سازی کمپین‌های تیم قرمز است. این کمپین‌ها با شبیه‌سازی مهاجمان واقعی، ارزش قابل سنجشی برای سازمان به همراه دارند.

در طول پنج فصل ساختارمند، خوانندگان دانش راهبردی و عملیاتی لازم برای موارد زیر را به دست می‌آورند:

- طراحی کمپین‌های تیم قرمز منطبق با چارچوب MITRE ATT&CK و تهدیدات خاص هر صنعت (مانند FIN۶ یا APT۲۹)
- ادغام الزامات مبتنی بر تطابق و مقررات (نظیر TIBER-EU و DORA) در برنامه‌ریزی و گزارش دهی مأموریت‌ها
- هماهنگی در زمینه قوانین درگیری (RoE)، رفع تداخل، عملیات امنیتی (OPSEC) و مدیریت چرخه عمر زیرساخت‌ها
- اجرای شبیه‌سازی‌های پیشرفته در محیط‌های ابری و ترکیبی با تمرکز بر سیستم‌های هویتی، کانتینرها و ابزارهای بومی ابر (Cloud)
- عملیاتی سازی خروجی‌های تیم قرمز به شکل بهبودهای کاربردی در تیم‌های SOC، واکنش به رخداد (IR)، حاکمیت و ریسک (GRC) و تیم‌های مهندسی
- ایجاد و ارزیابی بلوغ تیم قرمز از طریق نقشه راه، مدل‌های توانمندی و راهبردهای تعامل با مدیران ارشد

خوانندگان کتاب با طراحی و دفاع از یک برنامه جامع کمپین تیم قرمز در قالب سناریوی نهایی، کتاب را به پایان می‌رسانند. این پروژه نشان‌دهنده تسلط آن‌ها بر همسوسازی شبیه‌سازی مهاجم با ریسک تجاری، عمق فنی و الزامات قانونی خواهد بود.

چه به دنبال راه‌اندازی یک تیم قرمز جدید باشید، چه به دنبال تقویت نقش راهبردی آن یا هماهنگ‌سازی آزمون‌ها با الزامات مدیریتی و انطباقی، این کتاب چارچوب‌های حاکمیتی، روشی و تاکتیکی لازم برای موفقیت را در اختیار شما قرار می‌دهد.

فصل اول

حکمرانی استراتژیک تیم قرمز

t.me/cybershelf

۱،۱ - مقدمه‌ای بر تیم قرمز (Red Teaming)

هدف:

ایجاد درکی پایه‌ای از اینکه تیم قرمز چیست، چه نقشی در سازمان دارد و چگونه با آزمون‌های سنتی امنیتی تفاوت می‌کند.

۱. تعریف و هدف تیم قرمز

تیم قرمز یک شبیه‌سازی ساختاریافته و خصمانه است که تاکتیک‌ها، تکنیک‌ها و رویه‌های (TTPs) مهاجمان واقعی را بازآفرینی می‌کند تا توانایی‌های سازمان در شناسایی، واکنش و تاب‌آوری مورد ارزیابی قرار گیرد.

برخلاف تست نفوذ که بیشتر بر شناسایی و بهره‌برداری از آسیب‌پذیری‌ها تمرکز دارد، تیم قرمز افراد، فرآیندها و فناوری‌های سازمان را در شرایطی مشابه با یک نفوذ واقعی مورد آزمون قرار می‌دهد.

اهداف عملیات تیم قرمز عبارت‌اند از:

- شبیه‌سازی تهدیدات پیشرفته و ماندگار (APT)
- اجرای مخفیانه بدون اطلاع تیم آبی
- سنجش بلوغ عملیاتی در کل چرخه امنیت
- ارائه بازخورد واقعی درباره وضعیت دفاعی سازمان

۲. تفاوت تیم قرمز با تست نفوذ

تیم قرمز	تست نفوذ	دسته‌بندی
شبیه‌سازی مهاجمان واقعی	شناسایی آسیب‌پذیری‌های فنی	هدف
گسترده، بدون محدودیت یا با محدوده باز	محدود، با اهداف از پیش تعیین شده	دامنه
چند هفته تا چند ماه	چند روز تا دو هفته	مدت زمان
معمولاً بی اطلاع هستند	معمولاً مطلع هستند	آگاهی تیم آبی
ابزارهای سفارشی و تاکتیک‌های مشابه APT	ابزارهای استاندارد تست نفوذ	ابزارها

به‌طور خلاصه:

- تست نفوذ رویکردی تاکتیکی و متمرکز بر آسیب‌پذیری دارد.
- تیم قرمز رویکردی راهبردی و متمرکز بر رفتار مهاجمان دارد.

۳. تیم قرمز در بستر شبیه‌سازی مهاجم (Adversary Emulation)

مأموریت‌های تیم قرمز اغلب بر پایه اطلاعات تهدید (Threat Intelligence) طراحی می‌شوند تا پروفایل مهاجمان خاص شبیه‌سازی شود. این شامل موارد زیر است:

- انتخاب پروفایل مهاجمان مشخص (مانند FIN۶ یا APT۲۹)
- نگاشت TTP-ها بر اساس گزارش‌های اطلاعاتی
- بازسازی مسیرهای حمله واقعی از دسترسی اولیه تا دستیابی به اهداف نهایی

این رویکرد باعث می‌شود عملیات نه تنها از نظر فنی چالش‌برانگیز باشد، بلکه از نظر سازگاری با چشم‌انداز تهدیدات سازمان نیز معنا و ارزش داشته باشد.

۴. خروجی‌ها و ارزش برای سازمان

زمانی که مأموریت تیم قرمز با موفقیت انجام شود، نتایج زیر به دست می‌آید:

- شکاف‌های شناسایی در طول زنجیره کشتار (Kill Chain)
- ضعف‌ها در رویه‌های پاسخ به رخداد
- عدم همسویی بین سیاست‌ها و عمل واقعی
- شاخص‌های نفوذ (IOCs) که توسط دفاع موجود شناسایی نشده‌اند

ارزش نهایی تیم قرمز در این است که نشان دهد یک مهاجم چگونه می‌تواند در یک محیط واقعی به اهداف خود برسد و در نتیجه به سازمان کمک کند تا با بهبودهای آزمایش‌شده، تاب‌آوری خود را تقویت کند.

۱,۲ – اهداف تیم قرمز و ارزش آن برای سازمان

هدف:

توضیح اهداف راهبردی عملیات تیم قرمز و نشان دادن ارزشی که این رویکرد فراتر از شناسایی صرف آسیب‌پذیری‌ها برای سازمان ایجاد می‌کند.

۱. اهداف اصلی عملیات تیم قرمز

عملیات تیم قرمز به منظور شبیه‌سازی حملات پیچیده و واقعی طراحی می‌شود تا سطح بلوغ امنیتی سازمان سنجیده و تقویت شود. مهم‌ترین اهداف عبارت‌اند از:

آزمایش توان شناسایی:

بررسی اینکه ابزارها و تیم‌های امنیتی تا چه حد می‌توانند فعالیت‌های مشکوک را در مراحل مختلف حمله تشخیص دهند.

سنجش پاسخ‌گویی به رخدادها:

ارزیابی سرعت، دقت و هماهنگی تیم‌های داخلی در مهار تهدید و مقابله با آن.

بررسی کارایی کنترل‌های امنیتی در محیط واقعی:

به چالش کشیدن کنترل‌هایی مثل EDR، فایروال و تقسیم‌بندی شبکه برای اطمینان از اینکه در شرایط حمله واقعی به‌درستی عمل می‌کنند.

نمایش ریسک‌های واقعی کسب‌وکار:

ارتباط دادن مسیرهای فنی حمله با پیامدهای ملموس مانند سرقت داده، کلاهبرداری مالی یا اختلال در خدمات حیاتی سازمان.

۲. مزایای راهبردی برای سازمان

یک عملیات تیم قرمز حرفه‌ای می‌تواند مزایای بلندمدتی برای سازمان داشته باشد، ازجمله:

بهبود دفاع بر اساس تهدیدات واقعی:

همسو کردن توان شناسایی و پاسخ با رفتار مهاجمان واقعی، بر پایه چارچوب‌هایی مثل MITRE ATT&CK.

سنجش تاب‌آوری سازمان:

ارزیابی توان سازمان در برابر حملات چندلایه (انسانی، فرآیندی و فنی) که مشابه شرایط دنیای واقعی هستند.

ارائه بینش مدیریتی:

تبدیل نتایج فنی به زبان قابل فهم برای مدیران ارشد و نشان دادن اینکه سرمایه‌گذاری در امنیت چه نتایج ملموسی به همراه دارد.

توانمندسازی همکاری تیم‌ها (Purple Teaming):

ایجاد زمینه‌ای برای تمرین‌های مشترک بین تیم‌های تهاجمی (قرمز) و تدافعی (آبی) به منظور ارتقای سریع‌تر قابلیت‌ها.

۳. شاخص‌های سنجش و ارزیابی

برای بررسی اثربخشی عملیات تیم قرمز، معمولاً سازمان‌ها این شاخص‌ها را دنبال می‌کنند:

- میانگین زمان شناسایی (MTTD): چقدر طول می‌کشد تا فعالیت مخرب کشف شود.
 - میانگین زمان واکنش (MTTR): چقدر سریع تیم‌ها برای مهار و رفع تهدید اقدام می‌کنند.
 - پوشش شناسایی: چه بخشی از مسیر حمله ثبت، هشدار یا مسدود شده است.
 - دقت پاسخ‌گویی: آیا هشدارها منجر به اقدامات صحیح و به موقع دفاعی شده‌اند یا خیر.
- این شاخص‌ها نشان می‌دهند که فاصله بین تصور سازمان از امنیت خود و عملکرد واقعی در برابر تهدیدات چقدر است.

۴. محدودیت‌ها و ملاحظات

تیم قرمز جایگزین ارزیابی‌های سنتی امنیتی نیست و اهداف زیر را دنبال نمی‌کند:

- فهرست کردن همه آسیب‌پذیری‌ها (مانند تست نفوذ)
- تضمین شناسایی تهدیدات روز صفر (Zero-day)
- جایگزینی کامل با ارزیابی‌های امنیتی دیگر

ارزش واقعی تیم قرمز در این است که نشان می‌دهد سازمان در شرایط واقعی تا چه اندازه می‌تواند شناسایی کند، واکنش نشان دهد و خود را با تهدید تطبیق دهد.

۱,۳ - حاکمیت عملیاتی و مدل‌های تعامل تیم قرمز

هدف:

تعیین نحوه ساختاردهی، مدیریت و هدایت عملیات تیم قرمز به گونه‌ای که با اهداف کسب و کار، الزامات قانونی و استانداردهای اخلاقی همسو باشد.

۱. اصول حاکمیت تیم قرمز

حاکمیت عملیاتی چارچوبی را فراهم می‌کند که در آن فعالیت‌های تیم قرمز مجوز دهی، اجرا، نظارت و ارزیابی می‌شوند. اصول کلیدی عبارت‌اند از:

مجوز و نظارت (Authorization and Oversight):

تمامی مأموریت‌ها باید به تأیید رهبری تعیین شده برسند (معمولاً از طریق تیم سفید) و در محدوده قوانین مشخص شده در قواعد تعامل (RoE) انجام شوند.

مدیریت ریسک و اثرگذاری (Risk and Impact Management):

فعالیت‌ها باید با کمترین میزان اختلال عملیاتی و ریسک قانونی انجام شوند. این شامل برنامه‌ریزی دقیق برای کار با داده‌های حساس، سیستم‌های تولیدی و وابستگی‌های بیرونی است.

تفکیک وظایف (Separation of Duties):

نقش‌ها باید به طور واضح جدا باشند: تیم قرمز (تهاجم)، تیم آبی (دفاع) و تیم سفید (کنترل و ایمنی). این تفکیک برای حفظ یکپارچگی عملیات حیاتی است.

۲. مدل‌های اصلی تعامل (Engagement Models)

بسته به سطح بلوغ امنیتی سازمان و میزان پذیرش ریسک، عملیات تیم قرمز می‌تواند بر اساس یکی از مدل‌های زیر اجرا شود:

مدل	توضیح	موارد استفاده
پنهان / جعبه سیاه (Covert / Black Box)	تیم آبی از انجام مأموریت بی‌خبر است. هیچ دانش قبلی از زیرساخت به تیم قرمز داده نمی‌شود.	بهترین گزینه برای سنجش واقعی توان شناسایی و واکنش.
جعبه خاکستری (Gray Box)	بخشی از اطلاعات داخلی با تیم قرمز به اشتراک گذاشته می‌شود. تیم آبی ممکن است تا حدی در جریان باشد.	مناسب برای تست‌های کنترل شده با اهداف مشخص.

جعبه سفید (White Box)	دید کامل و همکاری مستقیم بین تیم قرمز و تیم آبی برقرار است. معمولاً در تمرین‌های تیم بنفش استفاده می‌شود.	ایده آل برای تنظیم دقت شناسایی، بهبود فرآیندها و دریافت بازخورد سریع.
------------------------	---	---

۳. نقش‌ها و مسئولیت‌های سازمانی

اجرای موفق عملیات نیازمند تعریف شفاف نقش‌ها در سطح عملیاتی و مدیریتی است:

اپراتور تیم قرمز (Red Team Operator – RTO):

اجرای شبیه‌سازی مهاجم با استفاده از TTP-های واقعی.

رهبر یا مدیر تیم قرمز:

نظارت بر برنامه‌ریزی، OPSEC، تخصیص منابع و رفع تعارض‌ها.

تیم سفید:

مسئولیت نظارت کلی، تضمین ایمنی و مدیریت فرآیندهای تصاعد (Escalation) را بر عهده دارد.

تیم آبی:

در سناریوهای مخفی بدون اطلاع قبلی دفاع می‌کند یا در تست‌های مشترک همکاری می‌نماید.

ذی‌نفعان و مدیریت ارشد:

مجوز عملیات را صادر کرده، ریسک باقیمانده را می‌پذیرند و خروجی گزارش‌ها را دریافت می‌کنند.

وجود پروتکل‌های ارتباطی شفاف بین این نقش‌ها قبل از شروع عملیات ضروری است.

۴. الزامات قانونی، اخلاقی و انطباقی

عملیات تیم قرمز باید کاملاً با قوانین جاری، سیاست‌های داخلی و استانداردهای صنعت همسو باشد. این شامل موارد زیر است:

- خودداری از دسترسی غیرمجاز به سیستم‌هایی که خارج از محدوده مأموریت هستند
- اطمینان از عدم آسیب به داده‌های مشتری یا خدمات حیاتی سازمان
- ثبت و مستندسازی تمامی اقدامات برای بازبینی پس از عملیات
- انطباق با چارچوب‌هایی مانند TIBER-EU یا NIST ۸۰۰-۵۳ در صورت لزوم

مقدمه‌ای بر مدیریت عملیات تیم قرمز

تمامی فعالیت‌ها باید قابل ره‌گیری و حسابرسی باشند تا شفافیت، مسئولیت‌پذیری و اعتماد سازمانی حفظ شود.

t.me/cybershelf

۱,۴ – محدوده بندی مأموریت (Engagement Scoping)

هدف:

تعیین محدوده عملیات تیم قرمز به گونه‌ای که واقع‌گرایی، ارزش کسب‌وکار، ایمنی و الزامات قانونی هم‌زمان رعایت شوند. یک مأموریت با محدوده بندی دقیق، تضمین می‌کند که انتظارات ذی‌نفعان برآورده شده و درعین حال یکپارچگی و امنیت آزمایش حفظ شود.

۱. هدف از محدوده بندی

محدوده بندی، مرزها و اهداف عملیات تیم قرمز را مشخص می‌کند و تضمین می‌کند که:

- مأموریت با اولویت‌های کسب‌وکار همسو باشد.
- سیستم‌های حیاتی محافظت یا از محدوده خارج شوند.
- الزامات قانونی و انطباق رعایت شوند.
- ریسک عملیاتی قبل، حین و پس از آزمایش مدیریت شود.

یک محدوده بندی مؤثر، همکاری محور است و بر نتایج روشن و قابل اندازه‌گیری متمرکز است.

۲. ابعاد کلیدی محدوده بندی

محدوده بندی تیم قرمز شامل چند حوزه اصلی است:

شناسایی اهداف (Target Identification):

تعیین اینکه کدام سیستم‌ها، شبکه‌ها، برنامه‌ها یا کارکنان داخل یا خارج از محدوده هستند.

مثال: «تمام سیستم‌های تولیدی که داده‌های حساس مشتری (PII) را پردازش می‌کنند، خارج از محدوده هستند.»

محدودیت‌های زمانی (Time Constraints):

مدت زمان مأموریت و دوره‌های ممنوعیت فعالیت برای عملیات حساس کسب‌وکار.

مدل تهدید و پروفایل شبیه‌سازی (Threat Model & Emulation Profile):

انتخاب نوع مهاجم (مثلاً APT۲۹ یا FIN۶) و TTP-های مرتبط بر اساس اطلاعات تهدید واقعی.

معیارها و اهداف موفقیت (Success Criteria & Objectives):

تعیین اینکه چه عملیاتی به‌عنوان موفقیت‌آمیز محسوب می‌شود. مثال‌ها:

مقدمه‌ای بر مدیریت عملیات تیم قرمز

- دسترسی به ادمین دامنه
- دسترسی به گزارش‌های مالی حساس
- عبور از کنترل‌های نقطه پایانی بدون شناسایی

قواعد تعامل (Rules of Engagement – RoE):

تعریف روش‌های مجاز، اقدامات ممنوعه، نقاط رفع تعارض و مسیرهای تصاعد. RoE شامل مواردی مانند:

- عدم اجرای حملات DoS
- عدم دسترسی فیزیکی مگر با مجوز
- استفاده اجباری از پیلودهای ایمن‌سازی شده
- پروتکل تماس در مواقع اضطراری

۳. دسته‌بندی ریسک و همسویی با کسب‌وکار

تمام فعالیت‌های تیم قرمز یکسان از نظر اثرگذاری نیستند. محدوده بندی باید با وظایف کسب‌وکار همسو باشد:

حوزه‌های با تأثیر بحرانی:

- پلتفرم‌های داده مشتری
- زیرساخت پردازش پرداخت
- رابط‌های قانونی و مقرراتی

ملاحظات ریسک عملیاتی:

- آیا حرکت جانبی مجاز است؟
- آیا می‌توان از حملات فیشینگ زنده استفاده کرد؟
- آیا اطلاعات حساب‌های تولیدی در محدوده هستند؟

در صورتی که دارایی‌های با ریسک بالا هدف قرار گیرند، ممکن است لازم باشد شبیه‌سازی به‌جای بهره‌برداری واقعی انجام شود تا یکپارچگی سیستم حفظ شود.

۴. تعامل و تأیید ذی‌نفعان

محدوده بندی باید با مشارکت ذی‌نفعان کلیدی انجام شود:

- حامیان اجرایی (Executive Sponsors): مجوز محدوده و پذیرش ریسک را صادر می‌کنند.

مقدمه‌ای بر مدیریت عملیات تیم قرمز

- تیم‌های حقوقی و انطباق (Legal & Compliance): مرزهای فعالیت را تأیید می‌کنند.
- تیم‌های IT و SOC (از طریق تیم سفید): بینش فنی و برنامه‌های پشتیبانی اضطراری ارائه می‌دهند.

تمامی طرف‌ها باید اسناد مأموریت (Engagement Charter) را بررسی و تأیید کنند که شامل موارد زیر است:

- محدوده و اهداف
- جدول زمانی
- اقدامات کاهش ریسک
- انتظارات گزارش دهی
- مسئولیت افراد بر اساس نقش‌ها (RACI matrix)

۵. اسناد و مدارک محدوده بندی

مدارک کلیدی برای رسمی کردن محدوده عبارت‌اند از:

- بیانیه کار (Statement of Work – SoW)
- قواعد تعامل (RoE)
- خلاصه پروفایل تهدید (Threat Profile Summary)
- راهنمای عملیاتی (Operational Playbook)
- فرم پذیرش ریسک (Risk Acceptance Form)

این اسناد باید در طول عملیات نگهداری و تحت کنترل نسخه باشند تا تغییرات قابل پیگیری باشند.

فصل دوم

برنامه‌ریزی و اجرای عملیات تهاجمی

t.me/cybershelf

۲،۱ - فازهای برنامه‌ریزی

هدف:

تشریح مراحل درگیر در برنامه‌ریزی یک عملیات Red Team (تیم قرمز)، با تأکید بر مدل‌سازی تهدید، آماده‌سازی عملیاتی و هماهنگی برای اطمینان از اجرای ایمن و مؤثر.

۱. برنامه‌ریزی به‌عنوان یک عملکرد راهبردی

برنامه‌ریزی پایه‌ی موفقیت عملیات تیم قرمز است. این کار تضمین می‌کند که:

- فعالیت‌ها هدف محور و مبتنی بر تهدید هستند.
- زیرساخت‌ها، payload-ها (بارهای مخرب/اجرایی) و روش‌های دسترسی به‌صورت ایمن آماده‌شده‌اند.
- عملیات با واقعیت‌های تجاری و فنی همسو است.

برنامه‌ریزی مؤثر ریسک را کاهش می‌دهد، واقع‌گرایی را افزایش می‌دهد و نتایج قابل‌اندازه‌گیری به همراه دارد.

۲. مراحل چرخه عمر برنامه‌ریزی

برنامه‌ریزی تیم قرمز معمولاً مراحل متوالی زیر را دنبال می‌کند:

a. مدل‌سازی تهدید و جمع‌آوری اطلاعات

اولین گام انتخاب یک پروفایل مهاجم یا عامل تهدید بر اساس موارد زیر است:

- اطلاعات تهدید (مانند نگاشت‌های MITRE ATT&CK)
- تهدیدات خاص صنعت
- دارایی‌های حیاتی سازمان (Crown Jewels) و عملکردهای کسب‌وکار

خروجی: شناسایی تکنیک‌ها، تاکتیک‌ها و روش‌ها (TTPs)، بردارهای دسترسی و مسیرهای حمله قابل اعمال.

b. تعریف اهداف و مقاصد عملیاتی

تیم قرمز باید موارد زیر را تعریف کند:

- اهداف فنی (مثلاً: دسترسی به دسترسی Domain Admin، استخراج داده‌های حساس)

- اهداف تاکتیکی (مثلاً: دور زدن EDR، اجرای فعالیت‌های پس از بهره‌برداری در یک VLAN خاص)

- اهداف راهبردی با اثر تجاری (مثلاً: آزمایش واکنش در برابر رخنه داده‌ها)

هر هدف باید قابل اندازه‌گیری باشد و با ارزش تجاری مرتبط شود.

c. طراحی زیرساخت و برنامه‌ریزی OPSEC

این مرحله شامل ایجاد موارد زیر است:

- زیرساخت فرماندهی و کنترل (C2) شامل redirector-ها، سرورهای payload و نقاط استیجینگ
- دامنه‌ها، VPS-ها و دامنه‌های امن و ناشناس (با روش‌هایی مانند domain fronting یا استفاده از زیرساخت CDN در صورت نیاز)
- اقدامات مقابله‌ای OPSEC برای اجتناب از شناسایی، مانند:
 - قدیمی‌سازی دامنه
 - شبیه‌سازی گواهی‌های TLS
 - شکل‌دهی به ترافیک برای ترکیب شدن با الگوهای مشروع

d. آماده‌سازی ابزارها و Payload-ها

آماده‌سازی ابزارهایی که با TTP-های عامل تهدید انتخاب‌شده مطابقت دارند:

- Payload-های دسترسی اولیه (مثلاً: فیشینگ، HTML Smuggling، اکسپلویت‌های راه دور)
 - ایمپلنت‌ها یا لودرهای سفارشی برای C2
 - راهکارهای مبهم‌سازی (مثلاً: تکنیک‌های NET، دور زدن AMSI، DLL Sideload) (DLL Sideload)
- اطمینان حاصل شود که payload-ها در محیط‌های آزمایشگاهی (sandbox) تست شده‌اند و با محدودیت‌های ایمنی سازگارند.

e. لجستیک و هماهنگی

ایجاد مکانیزم‌های هماهنگی با:

- تیم سفید: افراد تماس اضطراری، برنامه‌های جلوگیری از تداخل، تأیید مراحل استیجینگ
- ذی‌نفعان داخلی (از طریق کانال‌های امن): هم‌ترازی جدول زمانی، گزارش وضعیت
- بخش حقوقی/انطباق: تأیید رسمی فعالیت‌های شبیه‌سازی فعال

مقدمه‌ای بر مدیریت عملیات تیم قرمز

مستندسازی و نقاط بازبینی باید پیش از شروع عملیات تعریف شوند.

۳. بهترین شیوه‌های برنامه‌ریزی

- همیشه تکنیک‌ها را با ATT&CK نگاشت کنید تا قابلیت پیگیری حفظ شود.
- قرارگیری تست در محیط عملیاتی را با افزایش تدریجی محدود کنید (مثلاً: شروع با شناسایی منفعل، سپس افزایش سطح با تأیید).
- از برنامه‌های شبیه‌سازی (مانند آنچه برای FIN۶ یا APT۲۹ وجود دارد) به‌عنوان الگو هنگام ساخت مدل تهدید استفاده کنید.
- مطمئن شوید ابزارها انعطاف‌پذیر هستند: از Payload‌های یکسان برای همه اهداف استفاده نکنید؛ به چارچوب‌های ترکیبی (PowerShell، C#، C++) بر اساس دفاع‌های هدف توجه کنید.

۴. خروجی‌های فاز برنامه‌ریزی

در پایان برنامه‌ریزی، تیم قرمز باید موارد زیر را در اختیار داشته باشد:

- یک برنامه عملیاتی مبتنی بر تهدید
- اهداف نگاشت شده به ریسک‌های تجاری
- زیرساخت تقویت‌شده و آماده برای استقرار
- مسیر رفع تداخل و افزایش سطح
- Payload‌های اعتبارسنجی شده که با قوانین عملیات (Rules of Engagement) سازگار هستند

۲،۲ - راه‌اندازی زیرساخت

هدف:

توضیح چگونگی طراحی، استقرار و مدیریت زیرساخت تیم قرمز که از مخفی‌کاری، کنترل و ایمنی عملیاتی در طول عملیات پشتیبانی می‌کند.

۱. هدف از زیرساخت تیم قرمز

زیرساخت تیم قرمز ستون فقرات همه عملیات تهاجمی است. این زیرساخت باید:

- از فرماندهی و کنترل (C2) مخفیانه و قابل اعتماد پشتیبانی کند.
- امکان تحویل و آماده‌سازی انعطاف‌پذیر Payload-ها را فراهم کند.
- از انتساب یا ایجاد اختلال تصادفی جلوگیری نماید.
- با اصول OPSEC (امنیت عملیات) و محدودیت‌های دامنه تعامل سازگار باشد.

۲. اجزای زیرساخت و معماری

محیط‌های تیم قرمز معمولاً یک معماری چندلایه دارند که اغلب شامل لایه‌های زیر است:

a. لایه اپراتور (Operator Layer)

نقطه کنترل مهاجم:

- برای ارسال دستورات و مدیریت نشست‌ها استفاده می‌شود.
- باید ایزوله و تقویت شود (مثلاً: استفاده از VPN روی Tor، یا SSH مخفی).

b. لایه ریدایرکتور (Redirector Layer)

زیرساخت پروکسی که:

- آدرس IP واقعی سرور C2 را پنهان می‌کند.
- ترافیک را از طریق رله‌ها (HTTP، HTTPS، DNS، TCP) منتقل می‌کند.
- Domain Fronting، ریدایرکت CDN یا شکل‌دهی به ترافیک اعمال می‌کند.

تنظیمات رایج ریدایرکتور شامل:

- nginx یا Apache mod_rewrite معکوس
- Caddy با هدرهای سفارشی برای تحویل Payload-های HTTPS

مقدمه‌ای بر مدیریت عملیات تیم قرمز

c. لایه سرور C۲ (Server Layer C۲)

مدیریت ارتباط ایمپلنت‌ها و تحویل Payload:

- نمونه‌ها: Empire، Sliver، Covenant، Mythic، Cobalt Strike
- باید از رمزگذاری، جداسازی نشست‌ها و دور زدن sandbox پشتیبانی کند.
- کنترل‌های OPSEC: خواب (sleep)، تصادفی، jitter، شناسایی sandbox

d. سرور Payload / Stager

میزبانی و تحویل Payload:

- می‌تواند مبتنی بر وب (HTTPS)، SMB یا تحویل از طریق ایمیل باشد.
- بهتر است از MIME-encoded staging یا HTML Smuggling استفاده شود.
- باید دور زدن MOTW و راهکارهای مقابله با شناسایی الگوی ترافیک را پیاده‌سازی کند.

۳. ملاحظات OPSEC در زیرساخت

مخفی‌کاری و بقا حیاتی هستند. تکنیک‌های کلیدی شامل:

قدیمی‌سازی دامنه و مدیریت اعتبار:

دامنه‌ها را چند هفته یا چند ماه قبل ثبت کنید. از سرویس‌هایی با اطلاعات WHOIS معتبر و گواهی‌های SSL واقعی استفاده کنید.

هماهنگ‌سازی گواهی TLS:

پارامترهای گواهی TLS معتبر را شبیه‌سازی کنید (مثلاً با استفاده از Let's Encrypt یا زنجیره‌های گواهی کپی شده).

تنوع C۲:

چندین کانال ارتباطی (HTTPS، DNS، SMB) و مسیرهای جایگزین پیاده‌سازی کنید (مانند بیکن‌های دارای jitter، خواب جایگزین، دامنه‌های فریب‌دهنده).

استراتژی Sinkhole / Failover:

Dead-drop resolverها یا ریدایرکتورهای پشتیبان اضافه کنید تا در صورت مسدود شدن یا کشف زیرساخت، کنترل حفظ شود.

۴. استقرار و تست

پیش از استقرار:

- تمام کانال‌های C2 را در محیط‌های شبیه‌سازی SOC تست کنید.
- مطمئن شوید امضاهای Payload باعث هشدار در سیستم‌های EDR/AV متداول نمی‌شوند.
- مسیرهای خروجی (egress paths) را اعتبارسنجی کنید (مثلاً: باز بودن پورت ۴۴۳ خروجی).
- گزارش‌های ممیزی و نسخه بندی Payload-های مستقرشده را نگهداری کنید.

در طول عملیات:

- ترافیک C2 را برای ناهنجاری‌ها یا نشانه‌های شناسایی پایش کنید.
- مطمئن شوید Payload-ها فقط طبق قوانین عملیات (Rules of Engagement) ماندگاری دارند.

۵. نمونه ابزارهای زیرساخت تیم قرمز

Tools (ابزارها)	Component (اجزا)
fwddproxy, SOCat, Caddy, Nginx, Apache	Redirector
Covenant, Sliver, Mythic, Cobalt Strike	Servers C2
SharpLoader, Donut, MSFVenom	Payload Crafting
CDN, HTTPS C2, DNSCat2, تونلینگ ICMP, Frida, تصادفی سازی HTTP beacon	Transport / Evasion

۶. مستندسازی و تحویل

اطمینان حاصل کنید زیرساخت به‌طور کامل مستندسازی شده باشد، شامل:

- نام‌ها و IP-ها، ثبت دامنه‌ها
- پروتکل‌های C2 و زمان‌بندی beaoning
- رویه‌های قطع اضطراری یا تخریب زیرساخت
- استراتژی OPSEC برای هر مؤلفه

تیم سفید باید توجیه شده و جزئیات مربوط به جلوگیری از تداخل در زیرساخت را دریافت کند.

۲,۳ - جریان کاری اجرای عملیات

هدف:

توضیح رویکرد ساختاریافته برای اجرای عملیات تیم قرمز، شامل مراحل کلیدی، روش‌ها و تدابیر ایمنی عملیاتی به منظور حفظ مخفی کاری، واقع‌گرایی در اثرگذاری و کنترل.

۱. نمای کلی از جریان اجرای عملیات

فاز اجرای تیم قرمز، برنامه‌ریزی را به عمل تبدیل می‌کند. این فاز باید از یک جریان کاری منظم و قابل تکرار پیروی کند که امکان موارد زیر را فراهم می‌سازد:

- شبیه‌سازی کنترل شده مهاجم
- نفوذ تدریجی و مخفیانه
- ایمنی و انطباق در محدوده‌ی مشخص شده

اجرای عملیات معمولاً به پنج مرحله کلیدی تقسیم می‌شود:

۲. مراحل اجرای عملیات

a. شناسایی (Active و Passive)

جمع‌آوری اطلاعات اولیه برای شناسایی موارد زیر:

- سطح حمله خارجی (دامنه‌ها، IP-ها، سرویس‌های باز)
- نام‌ها، ایمیل‌ها و ساختار سازمانی کارکنان
- دارایی‌های عمومی در معرض دید (مثلاً: GitHub، بکت‌های ۳)

ابزارها و تکنیک‌ها:

- شناسایی منفعل: OSINT، WHOIS، شفافیت گواهی‌ها (Certificate Transparency)، اسکرپینگ لینکدین
- شناسایی فعال: Nmap، masscan، dnsrecon، aquatone

b. دسترسی اولیه (Initial Access)

ایجاد نقطه نفوذ با استفاده از TTP-هایی که با عامل تهدید انتخاب شده مطابقت دارند.

روش‌های رایج:

مقدمه‌ای بر مدیریت عملیات تیم قرمز

- فیشینگ (هدفمند یا با Payload Dropper)
- HTML Smuggling، اسناد مخرب (VBA، بهره‌برداری از CVE-ها)
- حساب‌های معتبر یا Credential Stuffing
- سوءاستفاده از سرویس‌های عمومی در معرض دید (مثلاً: RCE وب، دور زدن VPN)

Payload-ها باید:

- مبهم سازی شده باشند
- از شناسایی MOTW و EDR فرار کنند
- با زیرساخت C2 تعیین‌شده ارتباط برقرار کنند

c. پس از بهره‌برداری (Post-Exploitation)

ایجاد دید داخلی و اعتبارسنجی دسترسی.

اقدامات کلیدی:

- Enumeration (شمارش): اشتراک‌گذاری‌های شبکه، کاربران، اعتمادهای دامنه، نرم‌افزارهای نصب‌شده
- دسترسی به اعتبارنامه‌ها: استخراج هش‌ها، سوءاستفاده از LSASS، گرفتن توکن‌ها
- ارتقای دسترسی: دور زدن UAC، جعل توکن، سوءاستفاده از پیکربندی‌های اشتباه سرویس‌ها

ابزارها: Seatbelt، PowerView، BloodHound، Mimikatz، SharpHound

تمام اقدامات باید ملاحظات OPSEC را رعایت کنند:

- حداقل سازی سروصدا (مثلاً زمان‌بندی تصادفی)
- اجتناب از فعال‌سازی اکتشافی EDR
- استفاده از لودرهای درون حافظه‌ای یا بازتابی (Reflective Loaders)

d. حرکت جانبی و ماندگاری (Lateral Movement & Persistence)

گسترش دسترسی در سیستم‌ها یا ارتقای سطح دسترسی.

TTP-ها:

- حرکت جانبی: RDP، WMI، SMB، WinRM، PsExec، سرویس‌های راه دور
- ماندگاری: وظایف زمان‌بندی‌شده، کلیدهای رجیستری Startup، ربودن سرویس‌ها (Service Hijacking)

- حملات دامنه‌ای: AS-REP Roasting، Kerberoasting، DCSync

اطمینان حاصل کنید که روش‌های ماندگاری قوانین عملیات (RoE) را نقض نمی‌کنند. اگر ماندگاری خارج از محدوده است، از حضور مبتنی بر Beacon بدون تغییر در رجیستری یا راه‌انداز استفاده کنید.

e. اقدامات بر اهداف (Actions on Objectives) – شبیه‌سازی اثرگذاری

نمایش اثرگذاری حمله با حداقل ریسک برای کسب‌وکار.

نمونه‌ها:

- دسترسی به اشتراک‌گذاری فایل‌های حساس
 - استخراج داده‌های جعلی یا فریبده
 - حرکت به سمت محیط‌های حیاتی تولیدی (در صورت مجاز بودن)
 - شبیه‌سازی استقرار باج‌افزار یا اقدامات مخرب (به‌صورت کنترل‌شده و غیرعملیاتی)
- از Payload-های فریبده و نمونه‌های اثبات مفهوم (PoC artifacts) برای شبیه‌سازی ایمن اثرگذاری استفاده کنید.

از دست‌کاری مستقیم داده‌های واقعی تجاری خودداری کنید مگر آنکه صراحتاً مجاز باشد.

۳. تدابیر ایمنی عملیاتی

- ارتباط با تیم سفید: حفظ کانال امن و بلادرنگ برای افزایش سطح و تأییدیه‌ها
- ثبت لاگ و جلوگیری از تداخل: ثبت تمام فعالیت‌ها برای بازبینی پس از عملیات؛ بررسی زیرساخت و سیستم‌های هدف با تیم سفید برای جلوگیری از هم‌پوشانی یا تداخل
- مکانیزم‌های Fail-safe: پیاده‌سازی Kill-Switchها و اسکریپت‌های پاک‌سازی برای ایمپلنت‌ها، مکانیزم‌های ماندگاری و C2 در صورت توقف زودهنگام عملیات

۴. شاخص‌های قابل‌پیگیری در طول اجرا

- زمان دسترسی به دسترسی اولیه
- زمان شناسایی یا پاسخ‌گویی
- تعداد سیستم‌های نفوذ شده
- هشدارهای فعال‌شده توسط EDR یا SIEM (در صورت دسترسی پس از عملیات)

این شاخص‌ها به ارزیابی پوشش شناسایی و عملکرد پاسخ‌گویی کمک می‌کنند.

۵. انضباط و واقع‌گرایی عملیاتی

رفتار عامل تهدید باید به‌طور واقعی شبیه‌سازی شود:

- استفاده از تکنیک‌های واقعی (مانند Living-off-the-Land Binaries)
- رعایت مدت حضور مورد انتظار مهاجم (Adversary Dwell Time)
- اجتناب از میانبرهایی که از TTP-های انتخاب‌شده منحرف می‌شوند مگر در صورت ضرورت

این کار وفاداری در تست را تضمین کرده و ارزش یادگیری پس از عملیات را افزایش می‌دهد.

t.me/cybershelf

۲،۴ – رفع تداخل (Deconfliction) و ایمنی عملیاتی

هدف:

اطمینان از اینکه عملیات تیم قرمز بدون ایجاد اختلالات ناخواسته، از دست رفتن داده‌ها یا نسبت دادن اشتباه حمله (Attribution) انجام می‌شوند. این بخش، راهبردهای کاهش ریسک، پروتکل‌های رفع تداخل زنده و کنترل‌های ایمنی عملیاتی را تشریح می‌کند.

۱. چرا رفع تداخل و ایمنی اهمیت دارند

عملیات تیم قرمز، به‌ویژه در محیط‌های زنده، ذاتاً پر ریسک هستند. در صورت نبود رفع تداخل مؤثر:

- سیستم‌های واقعی تولید ممکن است تحت تأثیر قرار گیرند.
- تیم آبی (Blue Team) ممکن است فعالیت تیم قرمز را با حمله واقعی اشتباه گرفته و به‌طور غیرضروری سطح واکنش را بالا ببرد.
- فعالیت واقعی مهاجمان ممکن است نادیده گرفته‌شده یا با اقدامات تیم قرمز اشتباه گرفته شود.
- مصنوعات (Artifacts) تیم قرمز ممکن است باقی بمانند یا فراتر از محدوده تعامل گسترش یابند.

ایمنی عملیاتی، انجام اخلاقی و مسئولانه شبیه‌سازی‌های تهاجمی را تضمین می‌کند.

۲. مکانیزم‌های رفع تداخل

a. هماهنگی با تیم سفید (White Team Coordination)

یک تیم سفید مشخص به‌عنوان مرجع کنترل عمل می‌کند:

- از تمامی اقدامات تیم قرمز آگاهی کامل دارد.
- اختیار توقف اضطراری عملیات را در دست دارد.
- فهرست دارایی‌ها و مسیرهای افزایش سطح (Escalation Paths) را فراهم می‌کند.
- به‌طور مداوم به‌روزرسانی‌های فنی و عملیاتی را از تیم قرمز دریافت می‌کند.

اعضای تیم سفید معمولاً از بخش‌های ریسک، انطباق، مدیریت SOC یا نمایندگان فنی تعیین شده هستند.

b. کانال‌های ارتباط زنده

ایجاد ارتباط امن و مستقیم با تیم سفید:

- چت یا VOIP رمزگذاری شده (مانند Signal، Wire یا Slack خارج از باند)
- کدها یا پروتکل‌های افزایش سطح از پیش تعیین‌شده
- بررسی‌های منظم یا پیام‌های heartbeat

این امر امکان واکنش فوری را در صورت بروز موارد زیر فراهم می‌کند:

- تأثیر بر سیستم تولیدی
- واکنش بیش‌ازحد تیم آبی
- رفتار غیرمنتظره از Payload-ها یا زیرساخت

c. رفع تداخل فنی (Technical Deconfliction)

اجتناب از تداخل ناخواسته با فرآیندهای تولید یا سرویس‌های شخص ثالث از طریق:

- تأیید بازه‌های IP و فهرست سیستم‌ها با موجودی دارایی‌ها
- پیش‌آزمون مسیرهای خروجی (egress paths) زیرساخت C۲
- برچسب‌گذاری Payload-ها برای شناسایی داخلی (مثلاً با هدرها یا mutex-ها)
- اطلاع‌رسانی به تیم آبی از طریق تیم سفید هنگامی که پایش منفعل مورد نظر است (مانند تست‌های تنظیم SIEM)

۳. کنترل‌های ایمنی

a. ایمنی Payload

- استفاده از داده‌های جعلی یا فریبنده برای شبیه‌سازی استخراج داده‌ها.
- اجتناب از اجرای دستورات مخرب یا Payload-های آزمایش نشده.
- اعتبارسنجی تمام ایمپلنت‌ها در محیط‌های ایزوله قبل از استفاده.
- استفاده از اجرای درون حافظه‌ای یا غیر ماندگار در صورت امکان.

b. رمزهای عملیاتی

پیروی سخت‌گیرانه از قوانین تعامل (Rules of Engagement):

- عدم ایجاد ماندگاری اگر خارج از محدوده باشد.
- عدم حرکت جانبی فراتر از بخش‌های شبکه توافق شده.
- عدم تغییر داده‌های تولیدی مگر با مجوز.

تمام استثناءها باید حتی اگر جزئی باشند مستندسازی شوند.

مقدمه‌ای بر مدیریت عملیات تیم قرمز

c. رویه‌های Failsafe و بازگشت (Rollback)

آمادگی برای توقف زود هنگام یا افزایش سطح حادثه:

- پیاده‌سازی Kill-Switch در همه Payload-ها (مثلاً بر اساس شرایط Beacon).
- نگهداری اسکریپت‌ها یا اتوماسیون برای پاک‌سازی فایل‌های انداخته‌شده، تغییرات رجیستری یا وظایف زمان‌بندی‌شده.
- هماهنگی پاک‌سازی و اعتبارسنجی پس از عملیات با تیم‌های آبی و سفید.

۴. واکنش به ریسک در زمان واقعی

اگر مشکلی پیش آمد:

- بلافاصله عملیات را متوقف کنید.
 - تیم سفید را از طریق کانال افزایش سطح توافق شده مطلع کنید.
 - رویداد، سیستم تحت تأثیر و اقدام اصلاحی مورد نظر را مستند کنید.
 - تنها با تأیید رسمی عملیات را از سر بگیرید.
- باید ذهنیت رسیدگی غیر تنبیهی به حادثه حفظ شود تا یکپارچگی و اعتماد در تعامل باقی بماند.

۵. اعتبارسنجی پس از عملیات

پس از پایان اجرا:

- اطمینان حاصل کنید همه ایمپلنت‌ها، مکانیزم‌های ماندگاری و زیرساخت حذف یا غیرفعال شده‌اند.
- لاگ‌های DNS، فایروال و SIEM را برای فعالیت‌های باقی‌مانده بررسی کنید.
- یک نشست فنی با تیم‌های آبی و سفید برگزار کنید تا تأیید شود هیچ ریسک باقی‌مانده‌ای وجود ندارد.

این گام، خروج مسئولانه را تضمین کرده و از مثبت کاذب یا نسبت‌دهی اشتباه در عملیات دفاعی آینده جلوگیری می‌کند.

۲,۵ - شاخص‌ها و پایش مستمر در طول اجرای عملیات

هدف:

معرفی پایش بلادرنگ (Real-Time Monitoring) و شاخص‌های عملکردی (Performance Metrics) که برای حفظ آگاهی عملیاتی، سنجش موفقیت و کنترل کامل در طول تعامل تیم قرمز ضروری هستند.

۱. اهمیت پایش بلادرنگ

پایش مستمر در طول اجرای عملیات به تیم قرمز امکان می‌دهد:

- حفظ آگاهی موقعیتی (Situational Awareness) از دارایی‌های مستقر و فعالیت‌های اپراتورها.
- شناسایی نشانه‌های شناسایی یا مداخله تیم آبی (Blue Team).
- پاسخ به ناهنجاری‌ها، اختلالات یا شکست‌های عملیاتی.
- جمع‌آوری داده‌های عملیاتی برای پشتیبانی از گزارش دهی پس از تعامل.

پایش مؤثر، دقت، ایمنی و تحلیل اثرگذاری را بهبود می‌بخشد.

۲. دسته‌بندی شاخص‌ها برای پیگیری

a. شاخص‌های تاکتیکی (Tactical Metrics)

تمرکز بر موفقیت فنی و پیشرفت عملیات:

- زمان دسترسی اولیه (Initial Access Time): مدت زمان از شروع عملیات تا اولین بیکن (Beacon) یا نفوذ موفق.
- مسیرهای حرکت جانبی (Lateral Movement Paths): تعداد سیستم‌هایی که به آن‌ها نفوذ شده و سطوح دسترسی ارتقا یافته‌اند.
- نرخ موفقیت اجرای Payload (Payload Execution Success Rate): تعداد اجرای موفق Payload در مقابل ناموفق.
- پایداری نشست C2 (Session Stability C2): شامل تعداد نشست‌های قطع شده، عملکرد تغییر زمان‌بندی (Jitter) و رخدادهای از دست رفتن بیکن (Beacon Loss Events) است.

b. شاخص‌های شناسایی و پاسخ (Detection and Response Metrics)

برای ارزیابی اثربخشی تیم آبی و قابلیت دید ابزارهای امنیتی:

- میانگین زمان شناسایی (Mean Time to Detect – MTTD): سرعت شناسایی فعالیت مخرب توسط تیم آبی.
 - میانگین زمان پاسخ (Mean Time to Respond – MTTR): مدت زمان از شناسایی تا مهار یا اصلاح.
 - مثبت/منفی کاذب (False Positives / Negatives): مواردی که شناسایی انجام نشده یا به اشتباه نسبت داده شده.
 - فعالیت ثبت شده در لاگ‌ها در مقابل فعالیت ثبت نشده (Logged vs. Unlogged Activity): فعالیت‌هایی که در لاگ‌ها قابل مشاهده هستند در مقابل آن‌هایی که کاملاً نامرئی‌اند.
- این شاخص‌ها از ارزیابی‌های مبتنی بر MITRE ATT&CK و دفاع مبتنی بر تهدید پشتیبانی می‌کنند.

c. شاخص‌های سلامت تعامل (Engagement Health Metrics)

برای استفاده داخلی تیم قرمز:

- سلامت بیکن^۱ (Beacon Health): کیفیت سیگنال، چرخه‌های خواب (Sleep Cycles) و عملکرد jitter^۲ طبق پیکربندی.
 - یکپارچگی زیرساخت (Infrastructure Integrity): زمان فعال بودن C۲، وضعیت ریدایرکتورها، در دسترس بودن دامنه‌ها.
 - کارایی ابزارها (Tool Effectiveness): لاگ‌های خطا، الگوهای شناسایی، فرآیندهای مسدود شده.
 - نویز تعامل (Engagement Noise): حجم لاگ‌های تولیدشده، مصنوعات انتهایی (Endpoint Artifacts) یا افزایش ناگهانی تلومتری (Telemetry Spikes).
- نویز زیاد می‌تواند مخفی‌کاری را کاهش داده و واکنش‌های دفاعی را زود هنگام فعال کند.

^۱ Beacon (بیکن) به معنای سیگنال یا پیام دوره‌ای است که یک ایمپلنت (implant) یا بدافزار به سرور فرماندهی و کنترل (C۲) ارسال می‌کند.

^۲ تغییرات تصادفی در زمان‌بندی ارسال سیگنال‌ها یا بیکن‌ها برای جلوگیری از شناسایی.

۳. ابزارها و تکنیک‌های پایش

a. داشبوردهای تلوامتری بیکن (Beacon Telemetry Dashboards)

بیشتر چارچوب‌های مدرن C۲ (مانند Sliver, Mythic, Cobalt Strike) داشبوردهای زنده ارائه می‌دهند تا زمان فعال بودن نشست، خروجی وظایف و زمان‌بندی عملیاتی را پیگیری کنند.

b. لاگ‌ها و ثبت اقدامات اپراتور (Operator Logs and Journaling)

اپراتورها باید لاگ‌های ساختاریافته نگهداری کنند:

- اقدامات با مهر زمانی (Timestamped Actions)
- هش/نسخه Payload استفاده‌شده
- سیستم هدف و زمینه عملیات

این اطلاعات به نسبت‌دهی (Attribution)، رفع تداخل (Deconfliction) و تحلیل پس از عملیات کمک می‌کند.

c. پایش شبکه و میزبان (غیرمستقیم) (Network and Host Monitoring – Indirect)

تیم قرمز می‌تواند موارد زیر را پایش کند:

- حل پرس‌وجوهای DNS از دامنه‌های استیجینگ
- لاگ‌های دسترسی وب روی ریدایرکتورها
- فرکانس بازگشت بیکن (Endpoint Callback)

این شاخص‌ها می‌توانند شناسایی احتمالی توسط EDR یا شبکه، یا مسدود شدن مسیرهای خروجی توسط تیم آبی را نشان دهند.

۴. ارزیابی و سازگاری مستمر (Continuous Assessment and Adaptation)

تصمیمات عملیاتی باید بر اساس داده‌های زنده اتخاذ شوند:

- اگر کانال‌های C۲ مسدود شدند، به پروتکل یا ریدایرکتور جایگزین تغییر مسیر دهید.
- اگر Payload توسط AV/EDR شناسایی شد، نسخه‌های مبهم (Obfuscated Variants) استفاده کنید یا رفتار آن را تغییر دهید (مثلاً استفاده از باینری‌های موجود در سیستم -Living-off-the-Land Binaries).
- اگر تیم آبی شروع به شکار کرد، به پایش منفعل یا استخراج تغییر مسیر دهید.

این روش با مدل‌های شبیه‌سازی تهدید سازگار است و تاکتیک‌های واقعی مهاجمان را تقلید می‌کند.

۵. مستندسازی و یکپارچگی گزارش دهی

تمام شاخص‌های جمع‌آوری شده باید مستقیماً در موارد زیر استفاده شوند:

- بازسازی جدول زمانی تعامل
- ارزیابی TTP-ها نسبت به نگاشت‌های MITRE ATT&CK
- شناسایی شکاف‌های شناسایی (Detection Gap)
- گزارش‌های فنی و مدیریتی

این خروجی‌ها امکان جلسات بازبینی آگاهانه و بهبود دفاع در فاز بعدی را فراهم می‌کنند.

فصل سوم

هماهنگی پس از اجرای عملیات

t.me/cybershelf

۳,۱ - گزارش دهی عملیاتی

هدف:

توضیح فرآیند ساخت و ارائه گزارش‌های عملیاتی تیم قرمز به صورت کاربردی که یافته‌های فنی، پیامدهای استراتژیک و توصیه‌ها را به ذی‌نفعان فنی و اجرایی به وضوح منتقل کند.

۱. هدف از گزارش دهی تیم قرمز

گزارش دهی تیم قرمز چندین هدف دارد:

- انتقال اینکه چه دستاوردهایی حاصل شده و چگونه به آن‌ها دست یافته‌اند.
- شناسایی ضعف‌های کنترل امنیتی و نقص‌های فرآیندی.
- ارائه پایه‌ای ساختاریافته برای بهبود شناسایی، پاسخ و تاب‌آوری.
- ارائه بینش‌های فنی و اثرات تجاری به مخاطبان مختلف.

یک گزارش مؤثر، شکاف بین نتایج تهاجمی و ارتقای دفاعی را پر می‌کند.

۲. انواع گزارش‌های تیم قرمز

تحويل گزارش‌ها معمولاً به سه بخش اصلی تقسیم‌بندی می‌شود:

a. خلاصه اجرایی (Executive Summary)

مخاطب: رهبران ارشد، اعضای هیئت‌مدیره، مسئولان ریسک/انطباق.

عناصر کلیدی:

- اهداف و دامنه تعامل
- جدول زمانی و نتایج در سطح کلان
- ریسک‌های تجاری نشان داده‌شده (مثلاً دسترسی غیرمجاز به داده‌های حساس، عبور از کنترل‌ها)
- توصیه‌های استراتژیک بدون اصطلاحات فنی

هدف: انتقال ارزش و ریسک به زبان کسب‌وکار.

b. گزارش فنی / روایت جدول زمانی (Technical Report / Narrative Timeline)

مخاطب: مهندسان امنیت، تحلیل‌گران SOC، تیم آبی (Blue Team)، مدیران IT.

عناصر کلیدی:

- زنجیره حمله گام‌به‌گام: از دسترسی اولیه تا اهداف نهایی
- ابزارها، Payload-ها و TTP-ها مورد استفاده، با نگاشت ATT&CK
- جدول زمانی شناسایی در مقابل اقدامات تیم قرمز (در صورت امکان)
- لاگ‌ها، اسکرین‌شات‌ها، تلمتری بیکن (Beacon Telemetry) و مصنوعات فنی

هدف: بازسازی عملیات برای تنظیم دفاع، همبستگی و ارزیابی توانمندی‌ها.

c. ماتریس شکاف‌ها و توصیه‌ها (Gap and Recommendation Matrix)

مخاطب: تیم‌های دفاع و برنامه‌ریزی استراتژیک.

عناصر کلیدی:

- شناسایی ضعف‌ها در شناسایی یا پاسخ‌دهی
- نگاشت تکنیک‌های ATT&CK با شکاف‌های پوشش
- توصیه‌های اصلاحی برای هر تاکتیک (مثلاً بهبود لاگ‌ها، تنظیم EDR، آموزش آگاهی)
- نقشه راه اولویت‌بندی شده (ریسک بالا/متوسط/کم)

هدف: پشتیبانی از برنامه‌ریزی بهبود دفاع با زمینه مبتنی بر تهدید.

۳. مصنوعات پشتیبان (Supporting Artifacts)

برای اطمینان از شفافیت و قابلیت تکرار، شامل موارد زیر باشد:

- فهرست (Indicators of Compromise) IOC: دامنه‌ها، IP-ها، هش‌های Payload
- کد منبع Payload سفارشی (فقط برای استفاده داخلی)
- نمودارهای شبکه (بخش‌های هدف، مسیرهای حرکت جانبی)
- لاگ‌های زیرساخت C2 (Command and Control Infrastructure)
- لاگ‌های فعالیت بیکن (Beacon Activity Logs) با مهر زمانی (Time stamp)

تمام مواد باید پیش از ارائه، از داده‌های غیرمجاز (مثل اعتبارنامه واقعی یا اطلاعات شخصی حساس) پاک‌سازی شوند.

۴. تحویل و ارائه

گزارش‌های تیم قرمز نباید فقط ارسال شوند، بلکه باید به ذی‌نفعان مناسب ارائه شوند:

- جلسات توضیح فنی با SOC، مهندسی و تیم آبی برای مرور زنجیره حمله و شکست‌های شناسایی.
 - جلسات اجرایی با مالکین ریسک برای تطبیق یافته‌ها با نگرانی‌های عملیاتی و استراتژیک.
 - جلسات مرورهای بین بخشی (Cross-Functional Reviews) شامل تیم‌های انطباق (Compliance)، حقوقی (Legal) و عملیات IT زمانی که یافته‌ها بر سیستم‌هایی که مشمول قوانین یا استانداردهای خاص، یا عملکردهای حیاتی کسب‌وکار هستند تأثیر می‌گذارند.
- جلسات مرور تعاملی برای تأیید فرضیات و اطمینان از درک مشترک ضروری هستند.

۵. بهترین شیوه‌های گزارش دهی پس از تعامل

- گزارش‌ها را مبتنی بر شواهد و عینی نگه‌دارید.
- لحن غیر خصمانه حفظ شود تا فرهنگ همکاری تقویت شود.
- قابلیت اقدام را با پیوند دادن توصیه‌ها به شکاف‌های کنترل مشخص تضمین کنید.
- از چارچوب‌هایی مانند MITRE ATT&CK و D3FEND برای نگاشت حمله و دفاع استفاده کنید.

۳،۲ - یکپارچه‌سازی تیم بنفش و تطبیق با مقررات (DORA و TIBER-EU)

هدف:

ایجاد فرآیندهای همکاری پس از تعامل (Post-Engagement) بین تیم قرمز (Red Team) و تیم آبی (Blue Team) از طریق تیم بنفش (Purple Teaming) و تطبیق نتایج با چارچوب‌های مقرراتی مانند DORA و TIBER-EU.

۱. تیم بنفش چیست؟

تیم بنفش یک مدل تمرینی همکاری است که در آن تیم قرمز و تیم آبی باهم کار می‌کنند تا:

- شناسایی‌ها را به‌صورت بلادرنگ (Real-Time) اعتبارسنجی کنند.
- دید به مسیرهای حمله و جریان‌های پاسخ را به اشتراک بگذارند.
- از طریق بازخورد فوری و تنظیم، بهبودها را سریع‌تر پیش ببرند.

برخلاف آزمون‌های پنهان تیم قرمز که تیم آبی از آن آگاه نیست، تیم بنفش:

- یادگیری را از طریق همکاری تسهیل می‌کند.
- حلقه بازخورد برای بهبود کنترل‌ها را کوتاه می‌کند.
- تعامل‌ها را از ارزیابی صرف به توسعه توانمندی تبدیل می‌کند.

۲. جریان یکپارچه‌سازی پس از تعامل تیم قرمز

پس از تعامل تیم قرمز، فعالیت‌های تیم بنفش باید بر موارد زیر تمرکز کنند:

بازپخش مسیرهای کلیدی حمله (Replay of Key Attack Paths)

بازاجرای حملات به‌صورت ایمن درحالی‌که تیم آبی مشاهده، آزمایش و دفاع‌ها را تنظیم می‌کند.

هدف: شناسایی شناسایی‌های ازدست‌رفته، اعتبارسنجی کتابچه‌های پاسخ (Playbooks) و اصلاح منطق SIEM.

کارگاه‌های مهندسی شناسایی (Detection Engineering Workshops)

جلسات همکاری برای ساخت قوانین شناسایی سفارشی بر اساس تلمتری تیم قرمز.

خروجی: قوانین Sigma، امضاهای YARA و تهدیدشناسی غنی‌شده (Enriched Threat Intelligence).

محیط‌های آزمایشگاه شبیه‌سازی تهدید (Threat Simulation Lab Environments)

اجرای سناریوها در آزمایشگاه بنفش (Purple Lab) تفکیک‌شده با استفاده از ابزارهایی مانند Atomic Red Team، Caldera یا اسکریپت‌های دستی.

هدف: تمرین و اعتبارسنجی بدون خطر برای محیط تولید.

۳. تطبیق با الزامات TIBER-EU

چارچوب TIBER-EU (Threat Intelligence-Based Ethical Red Teaming) یک ابتکار اروپایی برای آزمایش تاب‌آوری سایبری مؤسسات مالی حیاتی با استفاده از تیم قرمز است. تیم بنفش در بهترین شیوه‌های آن به صراحت ذکر شده است:

تیم بنفش در جریان تعامل:

برای اعتبارسنجی فرضیات بدون ایجاد اختلال در محیط تولید (مثلاً آزمایش هشدارهای SIEM در طول تعامل).

تیم‌بندی بنفش پس از تعامل:

فاز رسمی پس از آزمون تیم قرمز برای:

- بازپخش زنجیره‌های حمله خاص
- اندازه‌گیری $MTTR^4$ / $MTTD^3$
- به‌روزرسانی قوانین شناسایی و پاسخ به‌صورت مشترک

TIBER-EU همکاری بین تیم‌های قرمز، آبی و سفید (White Teams) را برای تعبیه دفاع مبتنی بر تهدید در آزمون زیرساخت‌های حیاتی ترویج می‌کند.

۴. نگاشت به الزامات DORA

قانون تاب‌آوری عملیاتی دیجیتال (DORA) یک مقررات اتحادیه اروپا است که از نهادهای مالی می‌خواهد تاب‌آوری عملیاتی خود را نشان دهند و شامل موارد زیر است:

^۳ میانگین زمان شناسایی (Mean Time to Detect – MTTD)

^۴ میانگین زمان پاسخ (Mean Time to Respond – MTTR).

آزمون نفوذ پیشرفته هدایت‌شده توسط تهدید (Threat-Led Penetration Testing – TLPT):

معادل روحی TIBER-EU اما قانونی برای مؤسسات مالی و ارائه‌دهندگان ICT شخص ثالث.

اعتبارسنجی توانمندی‌های شناسایی و پاسخ:

سازمان‌ها باید نشان دهند نه تنها تست انجام می‌دهند، بلکه برای افزایش تاب‌آوری عمل می‌کنند.

گزارش دهی حادثه و نتایج تست: DORA^۵

مستلزم مستندسازی و گزارش دهی ساختاریافته حوادث شدید و نتایج آزمون است.

فاز تیم بنفش پس از عملیات تیم قرمز، انطباق با DORA را با موارد زیر پشتیبانی می‌کند:

- نشان دادن بهبود از نتایج TLPT
- مستندسازی توسعه توانمندی در پاسخ به شبیه‌سازی تهدید
- همسوسازی اقدامات تیم قرمز با معیارهای تاب‌آوری مانند اهداف زمان بازیابی (Recovery Time Objectives) و کارایی کنترل‌ها

۵. توصیه‌های برنامه‌ریزی تیم بنفش

ارتباط با TIBER/DORA	فعالیت‌ها	فاز
پشتیبانی از همسوسازی با طرح تست TIBER	تعریف شاخص‌های موفقیت مشترک و اهداف شناسایی	قبل از تعامل
امکان آزمایش قبل از فاز بسته شدن (TIBER)	ثبت لاگ منفعل، بازپخش شبیه‌سازی غیرتهاجمی	در طول تعامل
نشان دادن بهبود تاب‌آوری موردنیاز DORA	بازپخش حملات، اصلاح قوانین، تمرین‌های SOC	پس از تعامل

۶. ابزارهای تمرین تیم بنفش

- MITRE Caldera: شبیه‌سازی خودکار مهاجم
- Atomic Red Team: تست‌های ماژولار و نگاشت شده ATT&CK
- Elastic Detection Engineering: توسعه قوانین و شبیه‌سازی
- PurpleSharp / Prelude Operator: ابزار شبیه‌سازی سبک و خاص ویندوز

^۵ قانون تاب‌آوری عملیاتی دیجیتال (Digital Operational Resilience Act – DORA)

۷. خلاصه مزایای مقرراتی و عملیاتی

فواید قانونی (Regulatory Benefits) شامل مزایایی که سازمان با رعایت چارچوب‌ها و قوانین مانند TIBER-EU و DORA به دست می‌آورد، مثل رعایت الزامات قانونی و کاهش ریسک‌های نظارتی و فواید عملیاتی (Operational Benefits) شامل مزایایی که در عملکرد داخلی سازمان ایجاد می‌شود، مثل بهبود توانمندی تیم‌ها، افزایش تاب‌آوری، بهبود شناسایی و پاسخ به تهدیدات و ارتقای اثربخشی عملیات امنیتی است.

- TIBER-EU: ارائه مدل ساختاری برای تیم قرمز اخلاقی با تیم‌بندی بنفش برای اعتبارسنجی تاب‌آوری.
- تاب‌آوری عملیاتی دیجیتال DORA: تبدیل آزمون عملیاتی به الزام قانونی و نیازمند شواهد بهبود توانمندی.
- تیم بنفش: پل بین توانمندی‌های تیم قرمز و آبی و همسوسازی فعالیت‌های فنی با الزامات انطباق و بلوغ سازمانی.

۳,۳ – معیارها و بهبود مستمر

تعریف شاخص‌های کلیدی عملکرد (Key Performance Metrics) و مکانیزم‌های بازخورد که به سازمان‌ها امکان می‌دهد اثربخشی تعاملات تیم قرمز (Red Team Engagements) را اندازه‌گیری کرده و به بهبود مستمر عملیات امنیتی بپردازند.

۱. نقش معیارها در دفاع مبتنی بر تهدید

معیارها شواهد عینی و قابل‌اندازه‌گیری از موارد زیر ارائه می‌دهند:

- بلوغ شناسایی و پاسخ (Detection and Response Maturity)
- شکاف‌های دید در زنجیره حمله (Kill Chain Visibility Gaps)
- آمادگی عملیاتی در برابر رفتار واقعی مهاجم (Operational Readiness against Real Adversary Behavior)

تحلیل پس از تعامل بدون معیارهای ارزیابی ساختاریافته که با اهداف مبتنی بر تهدید و الزامات مقرراتی مانند TIBER-EU و DORA همسو باشند، کامل نخواهد بود.

۲. معیارهای عملکرد رایج تیم قرمز

الف. معیارهای شناسایی (Detection Metrics)

میانگین زمان شناسایی (MTTD – Mean Time to Detect):

زمان سپری شده بین اقدام مهاجم و اولین شناسایی.

پوشش شناسایی (Detection Coverage):

درصد تکنیک‌های حمله که هشدار یا لاگ تولید کردند.

تحلیل شکاف دید (Visibility Gap Analysis):

تکنیک‌هایی که استفاده شدند اما ثبت یا هشدار داده نشده‌اند (نگاشت به MITRE ATT&CK).

ب. معیارهای پاسخ (Response Metrics)

میانگین زمان پاسخ (MTTR – Mean Time to Respond):

زمان بین شناسایی و واکنش دفاعی (مهار یا اصلاح).

دقت تشدید (Escalation Accuracy):

اینکه آیا تیم‌های SOC/IR رویداد را به‌درستی به‌عنوان مخرب طبقه‌بندی کردند.

مقدمه‌ای بر مدیریت عملیات تیم قرمز

زمان اجرای Playbook

زمان لازم برای فعال کردن و اجرای رویه‌های پاسخ.

ج. معیارهای شبیه‌سازی مهاجم (Adversary Simulation Metrics)

زمان دسترسی اولیه (Initial Access Time):

زمان لازم برای نفوذ به اولین میزبان.

زمان ارتقای دسترسی (Privilege Escalation Time):

زمان بین دسترسی اولیه تا دستیابی به سطح دسترسی بالاتر (مثلاً Domain Admin).

عمق حرکت جانبی (Lateral Movement Depth):

تعداد سیستم‌های نفوذ شده، دامنه‌های عبور کرده یا VLAN-های دسترسی یافته.

زمان حضور شبیه‌سازی شده (Dwell Time – Simulated):

مدت زمانی که تیم قرمز در شبکه بدون شناسایی باقی‌مانده است.

۳. نگاشت معیارها به چارچوب‌ها

از طبقه‌بندی‌های استاندارد شده برای قرار دادن معیارها در چارچوب مناسب استفاده کنید.

کاربرد	چارچوب
پیگیری و دسته‌بندی تکنیک‌های استفاده شده یا شناسایی شده	MITRE ATT&CK
نگاشت کنترل‌های شناسایی و کاهش تهدید به مراحل حمله	D3FEND
اعمال معیارها در فازهای آزمون همکاری و اعتبارسنجی ریسک	TIBER-EU Purple Teaming
ارائه شواهد بهبود توانمندی و جدول زمانی شناسایی حوادث	DORA Compliance

۴. حلقه بهبود مستمر (Continuous Improvement Loop)

برای اطمینان از بلوغ عملیاتی فراتر از آزمون:

۱. جمع‌آوری درس‌های آموخته شده:

در جلسات پس از مرگ (Post-Mortem) یا بازخورد با تیم‌های قرمز، آبی و سفید (Red, Blue, White Teams).

۲. به‌روزرسانی محتوای شناسایی:

فعالیت تیم قرمز را به قوانین شناسایی تبدیل کنید (مثل Sigma, YARA, EQL).

مقدمه‌ای بر مدیریت عملیات تیم قرمز

۳. بهبود فرآیندها و Playbook-ها:

جریان‌های پاسخ، سیاست‌های کنترل دسترسی و پروتکل‌های تشدید را ارتقا دهید.

۴. پیگیری پیشرفت اصلاحات:

تکمیل توصیه‌ها را ثبت کرده و مسئولیت‌ها را به واحدهای کسب‌وکار اختصاص دهید.

۵. بازآزمایی یا اعتبارسنجی:

با استفاده از تمرین‌های تیم بنفش (Purple Team Exercises) یا شبیه‌سازی مهاجم هدفمند، اثربخشی بهبودها را تأیید کنید.

۵. گزارش دهی استراتژیک و معیارهای اجرایی

برای مدیران ارشد و هیئت‌های حاکمیت:

- امتیاز کاهش ریسک: بر اساس تعداد و شدت یافته‌های برطرف شده.
- افزایش پوشش: افزایش دید در طول تکنیک‌ها، تاکتیک‌ها و فرآیندهای ATT&CK.
- آمادگی انطباق: همسو با TIBER/DORA یا الزامات بخش خاص.
- بلوغ برنامه: پیشرفت از طریق مدل‌های بلوغ عملیاتی تعریف‌شده (مثل سطوح NIST CSF یا مدل‌های MITRE Engage).

۶. یکپارچه‌سازی در استراتژی تاب‌آوری سایبری

بهبود مستمر یک فعالیت تک‌مرحله‌ای پس از تعامل نیست، بلکه یک عملکرد تکرار شونده است. معیارهای تیم قرمز باید به موارد زیر تغذیه شوند:

- گزارش‌های سالانه ریسک سایبری
- شاخص‌ها و توافق‌نامه‌های عملکردی (KPIs and SLAs) SOC
- ارزیابی‌های تمدید بیمه سایبری
- آماده‌سازی برای حساسی و ارسال‌های مقرراتی

این کار نتایج تیم قرمز را فراتر از یافته‌های فنی برده و آن‌ها را به تصمیم‌گیری‌های استراتژیک کسب‌وکار متصل می‌کند.

۳,۴ - توسعه برنامه تیم قرمز

هدف از این بخش ایجاد چشم‌انداز بلندمدت و مدل عملیاتی برای بلوغ عملکرد تیم قرمز است، به‌طوری‌که توانمندی‌های امنیت تهاجمی (Offensive Security Capabilities) با ریسک‌های کسب‌وکار، تهدیدات محیطی و انتظارات قانونی همسو شود.

۱. انتقال از پروژه به برنامه

اگرچه بسیاری از تعاملات تیم قرمز به‌صورت تمرین‌های مستقل آغاز می‌شوند، سازمان‌هایی که دارای استراتژی دفاع سایبری فعال هستند به سمت حفظ یک برنامه مستمر تیم قرمز حرکت می‌کنند. ویژگی‌های کلیدی این برنامه شامل موارد زیر است:

- عملیات تکرارشونده و مبتنی بر تهدید (Recurring, Threat-Informed Operations)
- یکپارچگی با جریان‌های کاری تیم بنفش و مهندسی شناسایی (Detection Engineering)
- پشتیبانی استراتژیک از سوی رهبری و واحدهای حاکمیتی (Governance)
- توسعه تاکتیک‌ها و تکنیک‌ها بر اساس بازخورد (Feedback-Driven Evolution)

۲. اجزای اصلی برنامه بلوغ تیم قرمز

الف. مدیریت و هدایت برنامه (Program Governance)

- تعریف منشور برنامه، محدوده فعالیت‌ها و اهداف.
- تأمین حمایت اجرایی از سوی مدیران ارشد (مانند CISO^۶ یا CRO^۷).
- یکپارچه‌سازی با مدیریت ریسک، انطباق قانونی و واحدهای حسابرسی.

ب. برنامه‌ریزی شبیه‌سازی مهاجم

- نگهداری کتابخانه TTP-ها نگاشت شده به MITRE ATT&CK
- انتخاب منظم پروفایل‌های مهاجم بر اساس اطلاعات تهدید به‌روز (مثلاً FIN۶، APT۲۹ گروه‌های باج‌افزار)
- توسعه و استفاده مجدد از برنامه‌های شبیه‌سازی متناسب با بخش و محیط سازمان

ج. زمان‌بندی عملیاتی و تغییر حوزه تمرکز

- برنامه‌ریزی تعاملات به‌صورت فصلی یا دو بار در سال

^۶ CISO (Chief Information Security Officer): مدیر ارشد امنیت اطلاعات

^۷ CRO (Chief Risk Officer): مدیر ارشد ریسک

- تنوع در حوزه‌های تمرکز: داخلی در برابر خارجی، پیرامون هویت، ابری، OT/ICS، دسترسی‌ها یا تعامل با شخص ثالث.
- ترکیب عملیات پنهان و مشارکتی (Purple Team)

د. توسعه زیرساخت و توانمندی

- نگهداری زیرساخت C۲ ماژولار و مطابق OPSEC (در صورت نیاز)
- نگهداری و توسعه ابزارهای تهاجمی در مخازن کد امن
- اطمینان از مهارت تیم در چند زبان اسکریپت نویسی و پلتفرم‌ها و تکنیک‌های حرفه‌ای (مثلاً #C، PowerShell، Python، NET، تکنیک‌های مخفی سازی Obfuscation)

ه. نقش‌ها و توسعه مهارت تیم

توسعه تیم‌های چند رشته‌ای با تخصص در:

- دسترسی اولیه / عملیات فیشینگ
- توسعه Payload و Implant
- شمارش داخلی و حرکت جانبی (Lateral Movement)
- تیم‌بندی بنفش و مهندسی شناسایی
- برنامه‌ریزی عملیاتی و گزارش دهی

تشویق به دریافت گواهینامه‌ها (مثل CRYPTO، OSCE۳، OSEP) و مشارکت در جوامع شبیه‌سازی (مثل MITRE Engage و CTID).

۳. مدل بلوغ تیم قرمز

بلوغ تیم قرمز را می‌توان در چند بعد ارزیابی کرد:

ویژگی‌ها	سطح بلوغ
تعاملات یک‌باره؛ تأثیر یا پیگیری محدود	سطح ۰ - غیررسمی (Ad hoc)
تعاملات طبق روش‌شناسی ساختاریافته؛ گزارش‌ها به بهبود دفاع‌ها کمک می‌کنند	سطح ۱ - تاکتیکی (Tactical)
تیم قرمز با مدل‌های تهدید همسو، تیم‌بندی بنفش یکپارچه، معیارهای مستمر	سطح ۲ - استراتژیک (Strategic)
تیم قرمز بخشی از دفاع سایبری تطبیقی؛ توسعه توانمندی‌ها و تصمیم‌گیری معماری	سطح ۳ - مقاوم (Resilient)

رشد برنامه را با مدل‌های مقرراتی مانند TIBER-EU و اهداف تاب‌آوری عملیاتی تحت DORA^۸ همسو کنید.

۴. یکپارچه‌سازی میان واحدها و تیم‌ها

یک برنامه موفق تیم قرمز با موارد زیر هماهنگ می‌شود:

- تیم آبی: اعتبارسنجی دفاع و تنظیم شناسایی
- تیم بنفش: اجرای سناریو مشترک و بازخورد بلادرنگ
- تیم سفید: ایمنی، نظارت و کنترل تعامل
- اطلاعات تهدید: برای ارائه بینش مهاجم و اعتبارسنجی TTP
- مدیریت ریسک و انطباق: نگاشت یافته‌ها به پیامدهای عملیاتی و مالی سازمان و میزان مواجهه با الزامات قانونی.

۵. یادگیری مستمر و پیگیری تهدیدات

حفظ دیدگاه و آگاهی نسبت به روندهای حمله در حال تحول از طریق:

- مشارکت فعال در منابع اطلاعات تهدید (CTI Feeds) و گزارش‌های مهاجم
- شبیه‌سازی بازیگران تهدید نوظهور در بخش مربوطه (مثلاً گروه‌های Ransomware-as-a-Service)
- ارزیابی تکنیک‌های روز صفر (Zero-Day) و زنجیره تأمین
- یکپارچه‌سازی با کتابخانه شبیه‌سازی مهاجم MITRE Adversary Emulation Library و به‌روزرسانی‌های CALDERA

۶. اندازه‌گیری اثربخشی برنامه

شاخص‌های کلیدی عملکرد (KPIs) شامل:

- تعداد شکاف‌های شناسایی بحرانی برطرف‌شده
- کاهش میانگین زمان شناسایی و پاسخ (MTTD / MTTR) پس از تعامل
- استقرار قوانین مبتنی بر فعالیت تیم قرمز در SIEM/EDR
- ساعات آموزش تیم یا گواهینامه‌های کسب‌شده
- تعاملاتی که با مدل‌های تهدید و اولویت‌های مقرراتی همسو شده‌اند

۷. گسترش تلاش‌های تیم قرمز (Scaling Red Team Efforts)

برای گسترش بدون اضافه‌کاری:

- استفاده از خودکارسازی برای شناسایی و بهره‌برداری‌های رایج (مثل Caldera, Sliver)
- برون‌سپاری شبیه‌سازی‌های تخصصی (مثلاً محیط OT یا تکرار Zero-Day)
- ساخت کیت‌های شبیه‌سازی مختص تهدید برای استقرار سریع
- نگهداری پایگاه دانش از یافته‌های گذشته، درس‌های آموخته شده و قالب‌های زیرساخت قابل استفاده مجدد

فصل چهارم

یکپارچه‌سازی عملیاتی و استراتژی

آینده‌نگر

t.me/cybershelf

۴,۱ - تیم قرمز به عنوان یک کارکرد راهبردی امنیتی

هدف:

قرار دادن تیم قرمز نه صرفاً به عنوان یک توانمندی عملیاتی، بلکه به عنوان یک دارایی راهبردی که از طریق بینش‌های مبتنی بر تهدید، بر سرمایه‌گذاری امنیتی، تصمیمات معماری و وضعیت ریسک سازمانی (Enterprise Risk Posture) تأثیر می‌گذارد.

۱. تکامل نقش تیم قرمز

عملیات سنتی تیم قرمز اغلب بر ارزیابی آسیب‌پذیری‌های فنی یا آزمودن کنترل‌های دفاعی متمرکز است. یک کارکرد بالغ و درون‌سازمانی تیم قرمز باید:

- منبعی مستمر از بینش‌های مبتنی بر رفتار مهاجمان (Adversary-driven insight) باشد.
- بر حاکمیت ریسک (Risk Governance)، معماری و تصمیم‌گیری در سطح هیئت‌مدیره اثر بگذارد.
- میان لایه‌های امنیتی تاکتیکی، عملیاتی و راهبردی پل ارتباطی ایجاد کند.
- به عنوان عامل فعال تغییر عمل کند، نه صرفاً یک کارکرد دوره‌ای برای آزمون امنیت.

این تغییر، عملیات تیم قرمز را به یک کارکرد پشتیبان تصمیم‌گیری مبتنی بر هوش تهدیدات سایبری (Cyber Threat Intelligence-driven Decision Support) ارتقاء می‌دهد.

۲. هم‌راستایی راهبردی با ریسک سازمانی

یافته‌های تیم قرمز باید به زبان ریسک تجاری ترجمه شوند:

- نگاشت زنجیره‌های حمله (Attack Chains) به خدمات حیاتی کسب‌وکار (برای نمونه: سامانه‌های پرداخت، پلتفرم‌های زنجیره تأمین).
- کمی‌سازی اثرات بالقوه عملیاتی (برای نمونه: تقلب مالی، خروج داده‌ها (Data Exfiltration)، اختلال در سرویس).
- اطلاع‌رسانی به نقشه‌های حرارت ریسک (Risk Heatmaps)، داشبوردهای GRC (حاکمیت، ریسک و انطباق) و گزارش‌های سایبری در سطح هیئت‌مدیره.

با این کار، تیم قرمز کمک می‌کند تا نه تنها مشخص شود چگونه می‌توان به سیستم نفوذ کرد، بلکه پیامدهای تجاری در صورت عدم رفع آسیب‌پذیری‌ها نیز روشن شود.

۳. تأثیر بر معماری و مهندسی امنیت

یک تیم قرمز راهبردی و درون‌سازمانی به موارد زیر کمک می‌کند:

- بازیابی معماری‌ها: ارائه دیدگاه‌های تهاجمی درباره طراحی‌ها یا تغییرات پیشنهادی سامانه‌ها.
- ابتکارات Zero Trust: آزمودن بخش‌بندی (Segmentation)، مرزهای هویتی و اجرای سیاست‌ها.
- برنامه‌های مهاجرت به ابر (Cloud Migration) و DevSecOps: شناسایی ریسک‌ها در خطوط خودکارسازی (Automation Pipelines)، پیگیری‌های نادرست و کدهای زیرساختی (Infrastructure-as-Code).

فعالیت‌های تیم قرمز به اصلاح و بهبود معماری‌های مرجع (Reference Architectures)، استانداردهای پایه کنترل‌های امنیتی (Security Control Baselines) و الگوهای طراحی امنیتی (Security Design Patterns) کمک می‌کند.

۴. خروجی‌های راهبردی برای گزارش دهی

عملیات تیم قرمز باید مواد و گزارش‌هایی تولید کند که برای سطوح مختلف ذی‌نفعان طراحی شده باشند:

ذی‌نفع	تمرکز	تحویل دادنی (Deliverable)
هیئت‌مدیره / مدیران ارشد	تأثیر بر کسب‌وکار	خلاصه اجرایی (Executive Summary)، کارت‌های امتیاز ریسک (Risk Scorecards)
ریسک و انطباق	ضعف‌های کنترلی، گزارش دهی	نگاشت‌های ATT&CK، هم‌راستا سازی انطباقی (برای نمونه: DORA ماده ۱۱)
معماری و مهندسی	شکاف‌های دفاعی، آسیب‌پذیری سامانه‌ها	جداول زمانی زنجیره حمله (Attack Chain Timelines)، شکاف‌های کشف (Detection Gaps)، تحلیل تأثیر ابزارها
عملیات امنیت	بهینه‌سازی کشف تهدیدات	گزارش‌های TTP (تاکتیک‌ها، تکنیک‌ها و رویه‌ها)، فهرست IOC (شاخص‌های سازش)، سناریوهای قابل اجرا مجدد (Replayable Scenarios)

این رویکرد اطمینان می‌دهد که ارتباط راهبردی در سراسر سازمان حفظ شود و گزارش‌های تیم قرمز به خروجی‌های صرفاً فنی و جدا افتاده محدود نشوند.

۵. شاخص‌های کلیدی عملکرد (KPIs) و شاخص‌های راهبردی

برای سنجش ارزش تیم قرمز به‌عنوان یک دارایی راهبردی:

- درصدی از توصیه‌ها که در ابتکارات امنیتی بلندمدت ادغام شده‌اند.
 - کاهش زمان کشف یا بهبود پاسخ نسبت به تمرین‌های قبلی.
 - بهبود پوشش در برابر تکنیک‌های منتخب ATT&CK.
 - کاهش ریسک اجرایی که به کنترل‌های معتبر (Validated Mitigations) نسبت داده می‌شود.
 - قابلیت تکرار شبیه‌سازی تهدید در لایه‌های ابری، هویتی و درون سازمانی (On-prem).
- این شاخص‌ها نشان‌دهنده اثرگذاری بلندمدت بر کسب‌وکار هستند، نه صرفاً موفقیت‌های فنی کوتاه‌مدت.

۶. حفظ نفوذ راهبردی

تیم‌های قرمز باید:

- در کمیته‌های راهبری امنیت سایبری مشارکت کنند.
- به‌طور منظم مدیر ارشد امنیت اطلاعات (CISO) و ذی‌نفعان اجرایی را توجیه کنند.
- یافته‌ها را وارد چرخه‌های پذیرش ریسک و بازبینی سیاست کنند.
- با بخش‌های GRC، حقوقی و انطباق همکاری کنند تا نتایج آزمون‌ها را در چارچوب تعهدات سازمانی قرار دهند.

نهادینه‌سازی این نقش تضمین می‌کند که بینش‌های تیم قرمز به تاب‌آوری پایدار در سطح کلان سازمان منجر شود.

۴,۲ – عملیاتی سازی یافته‌ها در سراسر سازمان

هدف

تبدیل یافته‌های تیم قرمز (Red Team) از بینش‌های صرفاً فنی و مقطعی به بهبودهای سازمانی گسترده، از طریق ادغام آن‌ها در فرآیندها، چارچوب‌های حکمرانی (Governance Frameworks)، طراحی کنترل‌ها و مدیریت ریسک سایبری.

۱. از گزارش تا پاسخ

عملیات تیم قرمز داده‌های ارزشمندی در حوزه افراد، فرآیندها و فناوری تولید می‌کند. با این حال، این داده‌ها تنها زمانی مؤثر هستند که در سطح کل سازمان عملیاتی شوند.

گام‌های کلیدی:

- فراتر رفتن از گزارش دهی فنی و حرکت به سمت برنامه‌ریزی اصلاحی میان وظیفه‌ای (Cross-Functional Remediation Planning).
- ادغام یافته‌ها در ثبت‌های ریسک (Risk Registers)، فرآیندهای مدیریت تغییر (Change Management) و مرورهای معماری امنیت (Security Architecture Reviews).
- تبدیل مسیرهای حمله (Attack Paths) به بهبود در سیاست‌ها، رویه‌ها و کنترل‌های فنی.

نتیجه: خروجی‌های تیم قرمز به دانش سازمانی ماندگار تبدیل می‌شود، نه مشاهدات مقطعی.

۲. ادغام در چارچوب‌های کنترلی

یافته‌های تیم قرمز باید به چارچوب‌های امنیتی پذیرفته‌شده جهانی نگاشت (Mapping) شوند تا امکان اصلاح ساختاری فراهم شود.

چارچوب	نگاشت عملیاتی
CSF NIST ۸۰۰-۵۳ /	هم‌راستا سازی یافته‌ها با خانواده کنترل‌ها (مانند AC: کنترل دسترسی، AU: حسابرسی و پاسخگویی، IR: پاسخ به رخداد).
ISO ۲۷۰۰۱	تغذیه در چرخه بهبود مستمر و برنامه‌های درمان ریسک.
CIS Controls v۸	شناسایی کنترل‌های از دست‌رفته (مانند کنترل ۸: مدیریت لاگ‌های حسابرسی، کنترل ۱۳: پایش شبکه).
MITRE D3FEND	پیشنهاد سازوکارهای فنی برای کشف و پیشگیری از تکنیک‌های حمله خاص.

این نگاشت‌ها هم به کاهش فنی ریسک کمک می‌کنند و هم برای مستندسازی پایبندی سازمان به قوانین، مقررات و استانداردهای امنیتی (Compliance) سودمند هستند.

۳. هماهنگی میان تیم‌ها و برنامه‌ریزی اصلاحی

خروجی‌ها باید از طریق جلسات بازخورد ساختاریافته (Debrief Sessions) عملیاتی شوند:

- تیم آبی (Blue Team): بهبود تنظیم قوانین تشخیص تهدید، بهینه‌سازی اولویت‌بندی هشدارها و ارتقای توانایی مشاهده و پیگیری فعالیت‌ها و وضعیت امنیتی نقاط پایانی (Endpoint-ها) به‌صورت شفاف و جامع.
- مدیریت SOC: به‌روزرسانی محتوای SIEM، تنظیم آستانه هشدارها و تعیین چگونگی اقدام و مسیر رسیدگی به هشدارها و رخدادهای امنیتی در پلی‌بوک‌ها، شامل اینکه چه فرد یا تیمی باید در چه زمانی وارد عمل شود و چه اقداماتی انجام دهد.
- فناوری اطلاعات / زیرساخت: اجرای بخش‌بندی شبکه، بررسی نقاط ضعف سامانه‌های قدیمی، اصلاح پیکربندی‌های اشتباه.
- ریسک / GRC: هم‌راستا سازی یافته‌ها با سطح پذیرش ریسک سازمان و مستندسازی زمان‌بندی کاهش ریسک.

رهبری تیم قرمز باید اقدامات اصلاحی را پیگیری، مسئول مشخص کند و زمان‌بندی برای اعتبارسنجی یا آزمون مجدد تعیین نماید.

۴. نهادهای سازی درس‌های آموخته‌شده

برای تثبیت ارزش تیم قرمز باید فرآیندهای تکرارپذیر ایجاد شوند:

- به‌روزرسانی سیاست‌های امنیتی (مانند سیاست‌های مدیریت دسترسی، الزامات ثبت وقایع، پاسخ به فیشینگ).
- استفاده از یافته‌ها در برنامه‌ریزی تداوم کسب‌وکار و بازیابی پس از بحران (BC/DR)، تمرین‌های شبیه‌سازی (Tabletop Exercises) و ارزیابی ریسک طرف سوم.
- غنی‌سازی آموزش آگاهی‌بخشی کاربران با سناریوهای واقعی تهدید و شکاف‌های رفتاری.

نتیجه: ایجاد یک چرخه بهبود مبتنی بر شواهد که به بخش‌های مختلف سازمان خوراک می‌دهد.

۵. خودکارسازی و ادغام با ابزارها

در برنامه‌های پیشرفته‌تر، یافته‌های تیم قرمز می‌توانند از طریق ابزارها عملیاتی شوند:

- سکوهاي SOAR: خودکارسازی کشف و پاسخ به تکتیک‌ها، تکنیک‌ها و رویه‌ها (TTPs) که تیم قرمز تأیید کرده است.
 - ابزارهای مدیریت پیکربندی: اعمال خطوط مبنا (Baselines) با تنظیمات امنیتی بهینه و اصلاح‌شده برای کاهش آسیب‌پذیری‌ها با استفاده از ابزارهایی مانند Ansible یا Chef، بر اساس ضعف‌های کشف‌شده توسط تیم قرمز.
 - سکوهاي اطلاعات تهدید (TIPs): افزودن جزئیات و زمینه‌های بیشتر به شاخص‌های نفوذ (IOCs) و الگوهای رفتاری با استفاده از یافته‌های تیم قرمز، به گونه‌ای که تیم امنیتی بتواند تهدیدها را دقیق‌تر و با توجه به زمینه واقعی آن‌ها شناسایی و تحلیل کند.
- نتیجه: حلقه بازخورد بین حمله، دفاع و عملیات فشرده‌تر و کارآمدتر می‌شود.

۶. ساخت «حافظه عضلانی سازمانی»

یافته‌های تیم قرمز باید فراتر از بستن شکاف‌ها، به ابزار یادگیری سازمانی تبدیل شوند:

- آزمودن برنامه‌های پاسخ با استفاده از شبیه‌سازی و Purple Teaming (همکاری تیم قرمز و آبی).
- توسعه راهنماهای عملیاتی SOC و پلی‌بوک‌هایی برای پاسخ مرحله‌ای به هشدارها و رخدادهای امنیتی، بر اساس زنجیره‌های واقعی حمله، شامل تعیین مسئول هر اقدام، اولویت پاسخ و مراحل انجام کار.
- ایجاد سناریوهای تکرارپذیر برای نیروهای تازه‌وارد و آموزش‌های مستمر.
- اندازه‌گیری پیشرفت از طریق بازجاری حملات و اعتبارسنجی.

۷. نظارت اجرایی و شفافیت

برای اطمینان از پذیرش و دیده شدن گسترده اقدامات:

- خلاصه‌سازی اقدامات عملیاتی شده در داشبوردهای برنامه امنیت سایبری.
- گزارش پیشرفت در جلسات سه‌ماهه بازبینی ریسک یا کمیته‌های راهبری.
- برجسته‌سازی بهبودهای انجام‌شده به‌عنوان بخشی از آمادگی سازمان برای رعایت الزامات و استانداردهای DORA و اعمال اصلاحات لازم پس از تست‌های TIBER-EU.

نتیجه: تقویت ارزش سرمایه‌گذاری در تیم قرمز و نمایش یک وضعیت امنیتی بالغ و مقاوم.

۴,۳ – آمادگی مداوم برای رعایت مقررات

هدف:

استفاده از عملیات تیم قرمز برای برآورده کردن الزامات نظارتی مستمر و اطمینان از اینکه سازمان به‌طور پیوسته با استانداردهایی مانند TIBER-EU، DORA و سایر دستورالعمل‌های خاص حوزه فعالیت، همسو باقی می‌ماند.

۱. تغییر جهت به سمت رعایت مداوم مقررات

ممیزی‌های سنتی که تنها در یک نقطه زمانی انجام می‌شوند، دیگر در محیط‌های تهدید پویا کافی نیستند. چارچوب‌های نظارتی مدرن انتظار دارند سازمان‌ها نشان دهند که:

آزمون امنیتی مستمر انجام می‌دهند

- تصمیم‌گیری مبتنی بر تهدید (Threat-informed decision-making) دارند
- شواهد بهبود تاب‌آوری (Resilience) را ارائه می‌کنند
- عملیات تیم قرمز، در صورتی که به‌طور منظم و مستند انجام شود، شواهد زنده‌ای از اثربخشی کنترل‌های امنیتی و رعایت مقررات ارائه می‌کند.

۲. چارچوب‌های نظارتی که نیازمند یا پشتیبان تیم قرمز هستند

مقررات / چارچوب	اهمیت و کاربرد
TIBER-EU	مؤسسات مالی در اتحادیه اروپا ملزم به انجام تست‌های تیم قرمز مبتنی بر اطلاعات (Intelligence-led) هستند، شامل مراحل تیم بنفش (Purple Team) و گزارش دهی ساختاریافته.
DORA (EU)	آزمون‌های نفوذ مبتنی بر تهدید برای مدیریت ریسک فناوری اطلاعات و ارتباطات (ICT Risk) را الزامی می‌کند؛ نیازمند ارائه شواهد کاهش ریسک، قابلیت پاسخ به حادثه و تکرار دوره‌ای تست‌ها است.
FFIEC CAT (US)	استفاده از تیم قرمز برای ارزیابی بلوغ امنیت سایبری توصیه می‌شود.
Directive NIS۲	دفاع مبتنی بر تهدید برای نهادهای حیاتی و مهم در اتحادیه اروپا را تشویق می‌کند.
ISO/IEC ۲۷۰۰۱	تست‌های تهاجمی برای اعتبارسنجی کنترل‌ها در چارچوب مدیریت امنیت اطلاعات (ISMS) پشتیبانی می‌شود.

نتایج تیم قرمز باید مستند، قابل تکرار و همسو با الزامات رعایت مقررات باشند.

مقدمه‌ای بر مدیریت عملیات تیم قرمز

۳. خروجی‌های تیم قرمز که رعایت مقررات را تسهیل می‌کنند
برای پشتیبانی از رعایت مداوم مقررات، برنامه‌های تیم قرمز باید شامل موارد زیر باشند:

اسناد مأموریت و محدوده عملیات (Engagement Charters and RoEs)

تعریف واضح محدوده، اختیارات و پذیرش ریسک برای هر مأموریت.

گزارش‌های تکنیک‌های ATT&CK

نشان می‌دهد چه رفتارهایی از طرف مهاجم شبیه‌سازی، شناسایی یا از دست‌رفته‌اند.

(ATT&CK): چارچوبی برای طبقه‌بندی رفتارهای مهاجم و تکنیک‌های نفوذ در امنیت سایبری

شاخص‌های تشخیص و پاسخ (Detection and Response Metrics)

شامل زمان شناسایی (Time-to-detect)، مدت حضور تهدید (Dwell Time) و تحلیل پاسخ تیم آبی

(Blue Team Escalation Analysis)

ثبت روند اصلاح آسیب‌پذیری‌ها (Remediation Tracking Logs)

نشان می‌دهد ضعف‌ها پس از مأموریت چگونه و چه زمانی برطرف شده‌اند.

نمونه‌های باز آزمایشی تیم بنفش (Purple Team Replay Artifacts)

نشان‌دهنده بهبود از طریق تست مجدد و تنظیم تشخیص‌ها است.

این خروجی‌ها با انتظارات مستندسازی مراحل آزمون TIBER-EU و مفاد ماده ۱۱ و ۱۲ قانون DORA همسو هستند.

۴. ریتم کاری تیم قرمز و یکپارچه‌سازی با الزامات قانونی و مدیریتی
برای حفظ آمادگی:

- تنظیم دوره‌های تست تیم قرمز مطابق چرخه‌های نظارتی (مثلاً تست TLPT سالانه)
- چرخش محدوده مأموریت‌ها: پوشش نقاط انتهایی (endpoint)، مدیریت هویت (identity)، شبکه، محیط ابری (cloud) و سامانه‌های طرف ثالث.
- شامل کردن بازیگران تهدید مرتبط با حوزه کاری سازمان: مانند FIN۶ برای بخش مالی و APT۲۹ برای بخش دولتی.

- شبیه‌سازی تهدید زنجیره تأمین، باج‌افزار و تهدید داخلی بر اساس اولویت‌های قانونی و امنیتی سازمان.

یک تقویم داخلی ایجاد کنید تا فعالیت تیم قرمز مستقیماً در گزارش‌های حسابرسی، رعایت مقررات و جلسات هیئت‌مدیره منعکس شود.

۵. ردیابی و پشتیبانی از حسابرسی

حفظ شواهدی که امکان حسابرسی را فراهم می‌کند:

- مستندات مأموریت با کنترل نسخه (Version-controlled)
- لاگ‌ها و هش‌های payloadهای استفاده‌شده
- اسکرین‌شات‌ها و تاریخچه دستورات (با متادیتا)
- اسناد پذیرش ریسک داخلی با امضای مدیریت

تطبیق تکنیک‌ها، تاکتیک‌ها و روش‌ها (TTPs) با پوشش کنترل‌ها

(مثلاً ۵۳-۸۰۰ NIST ← D3FEND ← ATT&CK)

این امکان را به سازمان می‌دهد که فرآیند تست تهاجمی معتبر و مطابق مقررات را هر زمان که نیاز باشد ارائه کند.

۶. تیم قرمز به‌عنوان تسهیل‌کننده رعایت مقررات

برنامه‌های تیم قرمز که به‌خوبی یکپارچه شده‌اند:

- کنترل‌های تست‌نشده یا غیرعملیاتی را قبل از ناظران شناسایی می‌کنند
- کنترل‌های جایگزین (Compensating Controls) در حوزه‌های پرخطر را اعتبارسنجی می‌کنند
- طرح‌های مدیریت ریسک را با داده‌های واقعی حمله توجیه می‌کنند
- نگرش پیشگیرانه را نشان داده و نظارت ناظران را کاهش می‌دهند

به‌جای اینکه تیم قرمز صرفاً یک مرکز هزینه باشد، به اعتبارسنجی کنترل‌های رعایت مقررات و تسریع تاب‌آوری سازمانی تبدیل می‌شود.

۴,۴ - تیم قرمز در محیط‌های ابری و ترکیبی

هدف:

تطبیق عملیات تیم قرمز با زیرساخت‌های مدرن ابری و ترکیبی از طریق:

- استفاده از تکنیک‌های حمله بومی ابری (Cloud-native Attack Techniques)
- درک مدل‌های مسئولیت مشترک (Shared Responsibility Models)
- آزمون سرویس‌های ابری نوظهور
- همسویی با چارچوب‌هایی مانند MITRE ATT&CK for Cloud و DORA

۱. سطح حمله مدرن

با انتقال بار کاری سازمان‌ها به پلتفرم‌های ابری عمومی، خصوصی و ترکیبی (مثلاً AWS، Azure، GCP)، تاکتیک‌های سنتی تیم قرمز دیگر کافی نیستند. محیط‌های ابری ویژگی‌هایی را اضافه می‌کنند که نیازمند رویکرد خاص هستند:

- سطوح حمله مبتنی بر API
- مدل‌های دسترسی مبتنی بر هویت (IAM، OAuth، SAML)
- بار کاری بدون سرور (Serverless) و کانتینری
- معماری‌های رویدادمحور (مثلاً AWS Lambda، GCP Cloud Functions)

این تغییرات ایجاب می‌کند تیم قرمز از تاکتیک‌ها، تکنیک‌ها و رویه‌های خاص ابری (Cloud-specific TTPs) و ابزارهای مناسب استفاده کند.

۲. درک چشم‌انداز تهدید ابری

عملیات تیم قرمز در محیط ابری باید بر اساس موارد زیر شکل گیرد:

- مدل‌های خدمات ابری (Cloud Service Models): زیرساخت (IaaS)، پلتفرم (PaaS)، نرم‌افزار به‌عنوان سرویس (SaaS)؛ مسیرهای حمله بسته به محل مسئولیت متفاوت هستند (مثلاً زیرساخت در مقابل پیکربندی).
- مدل‌های امنیتی ارائه‌دهندگان ابری: AWS، Azure و GCP هر کدام کنترل دسترسی، ثبت لاگ و جداسازی منابع محاسباتی را متفاوت اجرا می‌کنند.
- ماتریس Cloud ATT&CK: تکنیک‌هایی مانند:
 - سوءاستفاده از اعتبارنامه‌های معتبر با استفاده از توکن یا کلید API سرقت‌شده

- پیکربندی نادرست سطل‌های ذخیره‌سازی (Storage Buckets)
- افزایش سطح دسترسی از طریق نقش‌های IAM با مجوز بیش‌ازحد
- حرکت جانبی از طریق فدراسیون هویتی ابری یا توکن‌های سرویس (منبع: MITRE ATT&CK for Cloud)

۳. حوزه‌های تمرکز تیم قرمز در ابری

حوزه	نمونه TTPها (تاکتیک‌ها، تکنیک‌ها و رویه‌ها)
دسترسی اولیه (Initial Access)	برنامه‌های در معرض عموم، کلیدهای API به سرقت رفته، استفاده مجدد از اعتبارنامه‌ها از طریق OAuth
دسترسی به اعتبارنامه‌ها (Credential Access)	استخراج کلید از سرویس‌های متادیتا، توکن‌های دسترسی از کانتینرها
ماندگاری (Persistence)	ایجاد درب پشتی (Backdoor) در توابع Lambda و سوءاستفاده از مجوزهای حساب‌های سرویس (Service Principal)
افزایش سطح دسترسی (Privilege Escalation)	سوءاستفاده از نقش‌های IAM با مجوز بیش‌ازحد، فرار از کانتینر به هاست
فرار از دفاع (Defense Evasion)	تغییر تنظیمات CloudTrail، غیرفعال کردن لاگ‌گیری یا عامل‌های مانیتورینگ

اثرات (Impact) تغییر محتوای S3، اختلال در CI/CD، استخراج منابع برای شبیه‌سازی این رفتارها در ارائه‌دهندگان مختلف از Stratus Red Team و MITRE Cloud Matrix استفاده کنید.

۴. ابزارها و چارچوب‌های شبیه‌سازی ابری

ابزارهای طراحی‌شده برای تیم قرمز ابری شامل:

- Stratus Red Team – خودکارسازی تکنیک‌های حمله در AWS، Azure، GCP
- Pacu (AWS) – چارچوب پس از بهره‌برداری برای محیط‌های AWS
- SkyArk / ScoutSuite / PMapper – شناسایی نقش‌های IAM و تحلیل مسیر حمله
- CloudGoat / Flaws.cloud – سناریوهای آموزشی آسیب‌پذیری طراحی‌شده
- GCP Hacking Techniques – ارجاع از Cloud HackTricks و منابع منتخب دیگر

بسیاری از این ابزارها از نقشه‌برداری MITRE و سناریوهای تیم بنفش (Purple Team Replay) برای اعتبارسنجی تشخیص پشتیبانی می‌کنند.

۵. ملاحظات عملیاتی امنیتی ابری (OPSEC)

عملیات ابری نیازمند احتیاط بیشتر است:

- قابل مشاهده بودن مسیر حسابرسی: بسیاری از فعالیت‌ها به‌صورت لحظه‌ای ثبت می‌شوند (مثلاً CloudTrail، Azure Monitor)
- ریسک شناسایی: IP منبع، زمان و شناسه حساب می‌تواند تیم قرمز را سریع شناسایی کند
- همپوشانی با اشخاص ثالث: محیط‌های مشترک یا ارائه‌دهندگان سرویس ممکن است فعالیت را به‌صورت غیرعمدی شناسایی کنند

بهترین روش‌ها:

- استفاده از محیط‌های ابری آزمایشی مجزا (Isolated Test Tenants) برای اجرای تکنیک‌های حمله با ریسک بالا
- هماهنگی قبلی با تیم سفید (White Team) برای لاگ‌گیری و جلوگیری از تداخل
- بررسی تمام اقدامات با سیاست استفاده مجاز ارائه‌دهنده سرویس

۶. همسویی با رعایت مقررات و مدیریت ریسک

فعالیت‌های تیم قرمز در محیط ابری به‌طور مستقیم از موارد زیر پشتیبانی می‌کند:

- تست‌های ماده ۱۲ DORA^۹ در محیط‌های ICT خارجی و شخص ثالث
- برنامه‌ریزی آزمون‌های TIBER-EU برای دارایی‌های حیاتی ابری
- شناسایی نقاط ضعف در پیاده‌سازی Zero Trust و مدل‌های حاکمیت ابری

خروجی‌ها می‌توانند در موارد زیر مورد استفاده قرار گیرند:

- بازبینی وضعیت امنیتی ابری (Cloud Security Posture Management – CSPM)
- حسابرسی سیاست‌های مدیریت دسترسی هویتی (IAM)
- مهندسی تشخیص در SOC بومی ابری

^۹ ماده ۱۲ این قانون، الزامی برای انجام تست‌های تاب‌آوری عملیاتی دیجیتال بر محیط‌های ICT (فناوری اطلاعات و ارتباطات) ارائه‌دهندگان خارجی و شخص ثالث (Third-party ICT providers) وضع می‌کند. هدف آن ارزیابی آمادگی سازمان در برابر حملات سایبری و اختلالات عملیاتی در سرویس‌های ارائه‌دهندگان خارجی یا محیط‌های ابری که سازمان به آن‌ها وابسته است.

۷. ادغام TTP-های ابری در برنامه‌های تیم قرمز

برای مقیاس دهی مؤثر:

- نگهداری کتابخانه تهدید ابری بر اساس MITRE ATT&CK و ریسک‌های خاص ارائه‌دهنده
- چرخش عملیات در محیط‌های چند ابری و ترکیبی
- هماهنگی با مهندسان امنیت ابری و تیم‌های پلتفرم برای اعتبارسنجی کنترل‌ها
- استفاده از یافته‌های تیم قرمز برای:
 - تعیین استانداردها و خط‌مشی‌های پایه‌ای برای افزایش امنیت زیرساخت‌ها و سرویس‌های ابری (Cloud Hardening Baselines)
 - اعتبارسنجی قالب‌ها (Template Validations)
 - یکپارچگی با DevSecOps

۴,۵ - شناسایی و دنبال کردن روندهای تهدید آینده و اجرای عملیات تیم قرمز به صورت تطبیقی و پویا

هدف:

آماده‌سازی برنامه‌های تیم قرمز برای همراهی با فناوری‌ها، چشم‌انداز تهدید و قابلیت‌های مهاجمان در حال ظهور از طریق:

- اتخاذ روش‌های تطبیقی (Adaptive Methods)
- مدل‌سازی پیشگیرانه تهدید (Proactive Threat Modeling)
- ادغام خودکارسازی و هوش مصنوعی

۱. نیاز به تطبیق‌پذیری در تیم قرمز

چشم‌انداز تهدید به سرعت در حال تغییر است. روش‌های سنتی تیم قرمز مبتنی بر چک‌لیست ثابت دیگر کافی نیستند، به‌ویژه در برابر:

- مهاجمان مجهز به هوش مصنوعی (AI-assisted adversaries)
- حملات زنجیره تأمین (Supply Chain Attacks)
- تهدیدات بومی ابری (Cloud-native threats)
- سوءاستفاده داخلی و تمرکز بر هویت (Insider and identity-focused abuse)

تیم‌های قرمز باید از رویکردهای واکنشی که تنها پس از وقوع تهدید اجرا می‌شوند، فاصله بگیرند و به سمت شبیه‌سازی پیشگیرانه حملات حرکت کنند. این شبیه‌سازی باید با استفاده از اطلاعات تهدید به‌روز، خودکارسازی عملیات و یادگیری مستمر تیم هدایت شود تا سازمان بتواند پیش از وقوع حملات واقعی، نقاط ضعف خود را شناسایی و اصلاح کند.

۲. وکتورهای تهدید و روندهای نوظهور

روندهای کلیدی که عملیات تهاجمی آینده را شکل می‌دهند:

مهاجمان مجهز به هوش مصنوعی (AI-Augmented Threat Actors)

- استفاده از مدل‌های زبان بزرگ (LLM) برای مهندسی اجتماعی، تولید payload-های فیشینگ و اسکریپت‌های دور زدن دفاع
- شناسایی و تطبیق خودکار payload
- حملات مبتنی بر Impersonation و Deepfake علیه سیستم‌های هویتی

تخریب زنجیره تأمین نرم‌افزار

- آلودگی وابستگی‌ها، سوءاستفاده از CI/CD، بسته‌های مخرب NPM/PyPI
- تمرکز تیم قرمز: تزریق حین ساخت، سوءاستفاده از اعتماد به Artifact-ها

آسیب‌پذیری‌های روز صفر در پلتفرم‌های مدرن (Zero-Day Exploits)

- آسیب‌پذیری‌های کرنل، فرار از Hypervisor ابری، دور زدن جداسازی کانتینر
- نیازمند پایش پیشگیرانه آسیب‌پذیری و آگاهی از Fuzzing

باچ‌افزار به‌عنوان سرویس (Ransomware as a Service – RaaS)

- شبیه‌سازی مدل‌های باج‌گیری چندمرحله‌ای: واسطه‌های دسترسی ← اپراتورهای بار ← مذاکره‌کنندگان پرداخت
- همسویی با گروه‌هایی مانند Conti، Black Basta، LockBit

استفاده از هویت موجود (Living-Off-Identity – LOI)

- سوءاستفاده از توکن‌های OAuth، SAML و روابط اعتماد فدراسیون هویتی در معماری‌های ابری و ترکیبی

۳. روش‌شناسی تیم قرمز پویا و پاسخگو به تهدیدها تیم‌های قرمز آینده‌نگر باید با ویژگی‌های زیر فعالیت کنند:

ادغام مستمر اطلاعات تهدید (Continuous Threat Intelligence Integration)

- ادغام مستقیم و لحظه‌ای اطلاعات تهدید سایبری (CTI) و به‌روزرسانی‌های چارچوب MITRE در برنامه‌های شبیه‌سازی حمله تیم قرمز

برنامه‌ریزی مبتنی بر سناریو (Scenario-Based Planning)

- سناریوهای تهدید انعطاف‌پذیر که بر اساس پاسخ‌های مدافعان قابل تغییر و تنظیم هستند

پشتیبانی تصمیم‌گیری با کمک ماشین (Machine-Assisted Decision Support)

- استفاده از یادگیری ماشین (ML) برای:
 - مدیریت زیرساخت‌ها
 - اولویت‌بندی مسیرهای حمله
 - توالی دستورات و تنظیم OPSEC

کتابخانه‌های TTP پویا (Dynamic TTP Libraries)

- نگهداری کتابخانه‌های ماژولار و کنترل‌شده از TTP-ها با امکان شخصی‌سازی زمان اجرا (مثلاً کانال‌های C2، payload-های دور زننده)

۴. خودکارسازی و هوش مصنوعی در عملیات تیم قرمز برای افزایش اثربخشی و مقیاس‌پذیری:

- استفاده از چارچوب‌های خودکارسازی (مثلاً Caldera، Stratus Red Team، Prelude Operator) برای اجرای تکنیک‌ها و بازپخش آن‌ها
- به‌کارگیری هوش مصنوعی مولد برای:
 - تولید سناریوهای فیشینگ هدفمند (Spear Phishing)
 - دور زدن امضاهای EDR
 - ایجاد تکنیک‌های سفارشی برای پوشاندن حمله

احتیاط: رمزهای اخلاقی و سیاست‌های استفاده ایمن از هوش مصنوعی باید به‌شدت رعایت شوند، به‌ویژه در بخش‌های تحت نظارت.

۵. آماده‌سازی برای آزمون تاب‌آوری پساکوانتومی و رمزنگاری

رمزنگاری پساکوانتومی (Post-Quantum Cryptography – PQC) تأثیر قابل‌توجهی بر سیستم‌های هویتی، ارتباطات امن و محرمانگی بلندمدت خواهد داشت.

تیم قرمز ممکن است آینده:

- الگوریتم‌های رمزنگاری ضعیف یا وصله نشده را آزمایش کند
- مکانیزم‌های TLS با بازگشت یا کاهش امنیت را بررسی کند
- سیستم‌های قدیمی که با مهاجرت به PQC سازگار نیستند را ارزیابی کند

زمان مناسبی برای مدل‌سازی تهدید مبتنی بر مفروضات رمزنگاری است.

۶. مهارت‌ها و ساختار تیم قرمز آینده

توانایی‌های کلیدی برای اپراتورهای نسل بعد:

- بهره‌برداری بومی ابری و کانتینرها
- سوءاستفاده از هویت و SSO (شامل Azure AD و Okta)

مقدمه‌ای بر مدیریت عملیات تیم قرمز

- مهندسی دستورات هوش مصنوعی و سوءاستفاده از مدل‌ها
- تحلیل باینری و توسعه بهره‌برداری (برای نقش‌های تحقیق تهاجمی)
- همکاری تیم بنفش و تنظیم تشخیص SOC

تیم‌های قرمز باید به گروه‌های امنیت تهاجمی بین‌رشته‌ای تبدیل شوند که برنامه‌نویسی، CTI، OPSEC و مهارت‌های سیستمی را ترکیب می‌کنند.

۷. یکپارچگی استراتژیک با برنامه‌ریزی تاب‌آوری برای حفظ اهمیت و ارزش‌آفرینی:

- یافته‌های تیم قرمز باید استراتژی تاب‌آوری سایبری را هدایت کنند، نه فقط اصلاحات فنی
- تیم قرمز آینده باید سناریوهای بحران را شبیه‌سازی کند، مانند:
 - پاسخ به تخریب زنجیره تأمین
 - همدستی داخلی با مهاجمان خارجی
 - حضور مهاجم در میانه فرآیند استقرار نرم‌افزار (Adversary-in-the-Middle)

۴،۶ - تعبیه تاب‌آوری تیم قرمز در عملیات روزمره سازمان

هدف

هدف این بخش، یکپارچه‌سازی فعالیت‌های تیم قرمز (Red Team) در عملیات امنیتی جاری سازمان، مدیریت تغییرات فناوری اطلاعات و حاکمیت ریسک است تا از شبیه‌سازی تهدیدات واقعی (adversary emulation) ارزش مداوم و قابل تکرار ایجاد شود.

این رویکرد تضمین می‌کند که سازمان نه تنها برای سنجش‌های دوره‌ای آماده باشد، بلکه در برابر تهدیدات واقعی، پاسخگو و انعطاف‌پذیر باشد.

۱. از پروژه‌های جداگانه به قابلیت‌های درونی

تیم قرمز نباید محدود به پروژه‌های کوتاه‌مدت و موقت باشد. سازمان‌های بالغ، عملیات تیم قرمز را به شکل زیر تعریف می‌کنند:

- یک قابلیت دائمی، نه یک رویداد زمان‌بندی شده
- یک کنترل پیشگیرانه، نه تنها آخرین مرحله آزمایش
- یک محرک یادگیری سازمانی، نه صرفاً یک آیتم برای رعایت الزامات انطباق

توضیح کاربردی: به جای اینکه تیم قرمز فقط در زمان ممیزی یا تست‌های سالانه فعال شود، باید به صورت مداوم در فرایندهای امنیتی و تصمیم‌گیری سازمان نقش داشته باشد تا یادگیری و بهبود مستمر اتفاق بیفتد.

۲. نقاط یکپارچه‌سازی در سراسر سازمان

فرایندهای تیم قرمز باید در گردش کارهای موجود سازمان جای بگیرند. مثال‌هایی برای آن در جدول زیر آورده شده است:

حوزه	نحوه یکپارچه‌سازی
مدیریت تغییرات (Change Management)	بررسی تغییرات با اثر بالا در IT برای شناسایی نقاط آسیب‌پذیری (مانند دامنه‌های جدید، دسترسی از راه دور، ابزارهای شخص ثالث).
خطوط DevSecOps	بازبینی تیم قرمز در خطوط CI/CD، مدیریت اسرار (Secrets Management) و پیکربندی‌های زیرساخت به عنوان کد (IaC) قبل از عرضه به تولید.

مدیریت آسیب‌پذیری	استفاده از زنجیره‌های حمله و مسیرهای بهره‌برداری برای باز وزن دهی CVSS و اولویت‌بندی رفع نقص‌ها.
پاسخ به حادثه	استفاده از سناریوهای تیم قرمز برای بهبود شناسایی، ارجاع و مهار حوادث.
حاکمیت و ریسک	تطبیق نتایج تیم قرمز با ثبت ریسک سازمانی، برنامه‌های کاهش ریسک و یافته‌های حسابرسی.

توضیح کاربردی: این یکپارچه‌سازی باعث می‌شود امنیت سایبری در تمام فعالیت‌های روزمره سازمان حضور داشته باشد و فقط محدود به تیم امنیت یا آزمایش‌های جداگانه نباشد.

۳. ایجاد تیم‌بندی پیوسته (Continuous Purple Teaming)

تیم‌بندی بنفش (Purple Teaming) پل عملیاتی بین شبیه‌سازی تهدیدات و مهندسی تشخیص است. برای استمرار آن:

- برنامه‌ریزی Sprintهای هفتگی یا ماهانه برای بازپخش تاکتیک‌ها، تکنیک‌ها و رویه‌های اخیر (TTPs)
- استفاده از فاصله‌های پوشش MITRE ATT&CK برای ایجاد وظایف عقب‌افتاده
- ایجاد چرخه بازخورد زمان واقعی بین مهندسان SOC و اپراتورهای تیم قرمز
- ترکیب مسیرهای حمله مبتنی بر ابر و هویت در بهینه‌سازی تشخیص

این کار باعث می‌شود تیم‌ها به سرعت یاد بگیرند، نقاط ضعف را شناسایی کنند و مدل‌های تشخیص را به‌طور پیوسته بهبود دهند.

۴. استفاده مجدد از کتابچه‌های عملیاتی و نگهداری دانش

تجربه تیم قرمز باید در قالب دانش عملیاتی سازمانی نگهداری شود:

- کتابخانه‌های داخلی TTP که با مراحل حمله هماهنگ هستند
- قالب‌های سناریو برای آموزش، تمرین‌ها و آزمون بازگشتی تشخیص
- یکپارچه‌سازی با پلتفرم‌های آموزشی برای تیم‌های SOC و IR
- ذخیره تلومتری و روایت فعالیت‌ها در پایگاه‌های دانش داخلی (مثل Wiki یا پلتفرم تهدید)

مزیت عملی: این کار حافظه عضلانی (muscle memory) سازمانی ایجاد می‌کند و پاسخگویی سازمان را در شرایط فشار و بحران پایدار می‌سازد.

۵. شاخص‌های اندازه‌گیری تاب‌آوری داخلی

شاخص‌های استخراج‌شده از تیم قرمز برای سنجش بلوغ سایبری تیم‌ها:

- تغییرات MTTR (میانگین زمان کشف تهدید) و MTTR (میانگین زمان پاسخ)
- بهبود پوشش تشخیص بر اساس تکنیک‌ها یا تاکتیک‌های ATT&CK
- نرخ موفقیت اجرای کتابچه‌های عملیاتی
- اثربخشی بهینه‌سازی SOC بر اساس تکنیک‌های بازپخش شده
- زمان‌بندی بین تیم قرمز تا اعمال اصلاحات در محیط تولید

کاربرد مدیریتی: این شاخص‌ها به رهبران سازمان کمک می‌کنند تا ROI سرمایه‌گذاری‌های امنیتی و روند تاب‌آوری عملیاتی را ارزیابی کنند.

۶. ایجاد عملیات تیم قرمز قابل تکرار و مقیاس‌پذیر

استراتژی‌های کلیدی:

- استفاده از زیرساخت C2 مدولار با نصب و حذف خودکار
- نگهداری کیت‌های شبیه‌سازی تهدید برای بازیگران کلیدی صنعت
- خودکارسازی شبیه‌سازی‌های کم ریسک با ابزارهایی مانند Caldera، Stratus Red Team یا Sliver
- ایجاد SLA داخلی برای اعتبارسنجی تشخیص و پیگیری سناریوها
- آموزش تیم‌های داخلی از طریق اجرای مشترک فعالیت‌ها با تیم‌های آبی/بنفش

مزیت عملی: شبیه‌سازی تهدیدات به بخشی از عملیات امنیتی روزمره سازمان تبدیل می‌شود.

۷. دستاوردهای راهبردی

تعبیه عملیات تیم قرمز باعث بهبود می‌شود:

- موضع تاب‌آوری سایبری در مواجهه با تهدیدات واقعی
- آمادگی سازمانی برای تست‌های قانونی و مقرراتی (مانند TIBER-EU، DORA، NIS ۲)
- افزایش آگاهی فرهنگی در مورد مسیرهای حمله و مالکیت ریسک در واحدهای کسب‌وکار
- توانایی واکنش سریع در برابر تهدیدات نوظهور

جمع‌بندی: تیم قرمز دیگر صرفاً یک آزمون نیست، بلکه به کاتالیزور تغییر سازمانی تبدیل می‌شود.

فصل پنجم

جمع‌بندی نهایی، ارزیابی و تبدیل به عملیات

t.me/cybershelf

۵.۱ - سناریوی پایانی: برنامه‌ریزی کامل تیم قرمز

هدف

هدف این تمرین، کاربرد جامع تمام دانش‌های دوره برای طراحی و مستندسازی یک عملیات کامل تیم قرمز است. طراحی باید بر اساس مدل تهدید واقعی، زمینه‌سازمانی و انطباق با مقررات انجام شود تا ارزش عملی و استراتژیک آن برای سازمان مشخص شود.

۱. مروری بر سناریوی پایانی

این تمرین، فرایند برنامه‌ریزی یک تعامل کامل تیم قرمز را شبیه‌سازی می‌کند؛ از مدل‌سازی تهدید تا هماهنگی پس از اجرای عملیات.

شرکت‌کنندگان باید یک طرح کمپین رسمی تولید کنند که نشان‌دهنده:

- تفکر استراتژیک
- انضباط عملیاتی
- آگاهی از الزامات قانونی و مقرراتی

باشد.

۲. پارامترهای سناریو

شرکت‌کنندگان می‌توانند یکی از گزینه‌ها را انتخاب یا به آن اختصاص داده شوند:

- بخش صنعتی (Sector): مانند مالی، انرژی، دولت
- محیط هدف (Target Environment): مانند زیرساخت ترکیبی با Azure AD و دامنه داخلی
- زمینه مقرراتی (Regulatory Context): مثلاً تمرین الزامی TIBER-EU با الزامات انطباق DORA
- پروفایل مهاجم (Adversary Profile): مانند FIN۶ برای حملات مالی محور یا APT۲۹ برای عملیات جاسوسی

توضیح کاربردی: هر برنامه باید واقعیت‌های فنی، رویه‌ای و سازمانی مربوط به محیط انتخاب‌شده را در نظر بگیرد.

۳. اجزای ضروری برنامه

یک طرح کامل کمپین تیم قرمز باید شامل بخش‌های زیر باشد:

الف. مدل تهدید و برنامه شبیه‌سازی مهاجم

- انتخاب عامل تهدید و توجیه آن
- مرور TTP-های تاریخی با نقشه‌برداری MITRE ATT&CK
- مسیرها و تکنیک‌های انتخابی برای شبیه‌سازی
- اهداف مورد انتظار (مثلاً دسترسی به داده‌های مالی یا حفظ حضور در Azure)

ب. برنامه‌ریزی عملیاتی

- دامنه تعامل و موارد مستثنا
- برنامه زیرساخت (طراحی C۲، ریدایرکتورها، ایزولاسیون)
- استراتژی‌های Payload و ابزارها (ابزارهای سفارشی یا آماده)
- اقدامات OPSEC (Operational Security) مانند ثبت دامنه و رعایت بهداشت عملیاتی
- روش‌های دسترسی اولیه (مثلاً فیشینگ یا برنامه‌های در معرض دسترس)

ج. قوانین تعامل و کنترل‌های ایمنی

- فعالیت‌های از پیش تأییدشده و فرایند جلوگیری از تداخل
- طراحی کلید قطع اضطراری (Emergency Kill Switch)
- شبکه‌ها و سطوح دسترسی در دامنه مجاز
- همکاری با تیم سفید (White Team) و تیم آبی (Blue Team)

د. شاخص‌ها و معیارهای موفقیت

- تاکتیکی: تعداد سیستم‌های دسترسی یافته، سطوح دسترسی
- استراتژیک: نرخ شناسایی، زمان پاسخ
- عملیاتی: زمان فعالیت beacon، پایداری زیرساخت
- انطباقی: تطابق با مواد ۱۱-۱۲ DORA یا مراحل تست TIBER-EU

ه. هماهنگی پس از اجرای عملیات

- ساختار گزارش دهی: خلاصه اجرایی، جدول زمانی فنی، ماتریس شکاف کنترل
- استراتژی بازپخش Purple Team
- پیگیری اصلاحات و مستندسازی درس‌های آموخته‌شده
- انتقال دانش به تیم‌های SOC و مهندسی دفاعی

مقدمه‌ای بر مدیریت عملیات تیم قرمز

۴. راهنمای ارزیابی

هر طرح بر اساس موارد زیر ارزیابی خواهد شد:

- واقع‌گرایی شبیه‌سازی تهدید
- کامل بودن جزئیات عملیاتی
- آگاهی از محدودیت‌های سازمانی (مثلاً میزان تحمل ریسک، طراحی زیرساخت)
- تطبیق با چارچوب‌های مقرراتی مرتبط
- سخت‌گیری در برنامه‌ریزی OPSEC و ایمنی
- بینش استراتژیک نسبت به تأثیر کسب‌وکار و ارزش بلندمدت

۵. اختیاری: اجرای تیمی

در صورت امکان، تیم‌ها می‌توانند هماهنگی عملیاتی واقعی را شبیه‌سازی کنند:

- رهبر تیم قرمز (Red Team Lead)
- اپراتورها (Operators)
- افسر امنیت عملیاتی (OPSEC Officer)
- رابط تیم سفید (White Team Liaison)
- مشاور انطباق (Compliance Advisor)

توضیح کاربردی: این تمرین، همکاری بین‌رشته‌ای را شبیه‌سازی می‌کند و عملکرد تیم‌ها را مطابق عملیات واقعی سازمان‌ها تقویت می‌کند.

۵,۲ - نقشه راه بلوغ مبتنی بر تهدید

هدف

تدوین یک نقشه راه چندساله برای توسعه عملکرد تیم قرمز، به گونه‌ای که این تیم از سطح تست‌های پروژه‌ای و مقطعی به یک قابلیت استراتژیک و تعبیه‌شده در سازمان ارتقا یابد. این قابلیت باید با دفاع مبتنی بر تهدید (Threat-Informed Defense) و مدیریت ریسک کسب‌وکار همسو باشد.

۱. چرا نقشه راه بلوغ ضروری است؟

قابلیت تیم قرمز نمی‌تواند در محیطی که تحت تأثیر عوامل زیر دائماً تغییر می‌کند، ایستا بماند:

- تکامل تاکتیک‌های مهاجمان
- الزامات انطباق و نظارتی (مانند PCI DSS، NIS۲، DORA)
- تحولات فناوری (مانند Cloud-Native و Zero Trust)
- تحول دیجیتال در سطح کلان سازمانی

یک نقشه راه بلوغ تضمین می‌کند که سرمایه‌گذاری‌های مربوط به تیم قرمز هدفمند (Intentional)، قابل اندازه‌گیری (Measurable) و پایدار (Sustainable) باشند و بتوانند سال‌به‌سال برای سازمان ارزش عملیاتی و استراتژیک ایجاد کنند.

۲. مدل بلوغ پایه‌ای تیم قرمز

یک مدل لایه‌ای برای پایه‌گذاری و پیش‌بینی مسیر تکامل تیم قرمز:

ویژگی‌ها	سطح بلوغ
تست‌های غیر ساختاریافته یا برون‌سپاری شده، بدون همسویی با مدل‌های تهدید	سطح ۰ - موردی (Ad Hoc)
اجرای تعاملات مشخص با برنامه‌ریزی مبتنی بر MITRE ATT&CK و گزارش دهی فنی	سطح ۱ - تاکتیکی (Tactical)
همسویی تیم قرمز با Purple Team، CTI (اطلاعات تهدیدات سایبری) و تیم‌های مهندسی؛ پیگیری بهبودها پس از تعامل	سطح ۲ - یکپارچه (Integrated)
تأثیرگذاری بر موضع ریسک، تغذیه تصمیمات سطح هیئت‌مدیره، پشتیبانی از حسابرسی‌های انطباق	سطح ۳ - استراتژیک (Strategic)

سطح ۴ - تاب آور (Resilient)	تعبیه توانمندی‌های تیم قرمز در خطوط CI/CD، بازیابی معماری و اعتبارسنجی مستمر دفاع
--------------------------------	---

این مدل به شناسایی شکاف‌ها در حوزه افراد، فرایندها و ابزارها کمک می‌کند.

۳. ورودی‌های لازم برای برنامه‌ریزی نقشه راه

رهبران تیم قرمز پیش از طراحی نقشه راه باید مجموعه‌ای از عوامل کلیدی را ارزیابی کنند. این عوامل تضمین می‌کنند که برنامه‌ریزی با تهدیدات واقعی، نیازهای سازمان و الزامات قانونی همسو باشد:

شکاف‌های پوشش تهدید

- بررسی کنید کدام تاکتیک‌ها، تکنیک‌ها و رویه‌های مهاجمان (TTPs) بر اساس چارچوب MITRE ATT&CK هنوز در شبیه‌سازی‌ها یا تست‌های سازمان پوشش داده نشده‌اند.
- مثال: اگر تاکتیک‌های حمله به زیرساخت ابری تاکنون تست نشده‌اند، این یک شکاف مهم است.

قابلیت ابزارها و زیرساخت‌ها

- میزان کارایی و توان ابزارهای موجود برای شبیه‌سازی تهدید و اجرای عملیات تیم قرمز باید مشخص شود.
- مثال: آیا زیرساخت Command & Control داخلی وجود دارد یا وابستگی کامل به ابزارهای متن‌باز است؟

سطح مهارت تیم

- ارزیابی توانمندی‌های اعضا در حوزه‌هایی مثل توسعه ابزارهای آفندی (Offensive Development)، عملیات ابری (Cloud Operations) و بهره‌برداری از هویت (Identity Exploitation).
- این بخش مشخص می‌کند که تیم برای اجرای سناریوهای پیچیده به چه آموزش یا نیروی جدیدی نیاز دارد.

یکپارچگی عملیاتی

- بررسی ارتباط و هماهنگی تیم قرمز با تیم‌های دیگر:
 - Purple Team (برای بازخورد و هماهنگی دفاع-حمله)،
 - SOC (مرکز عملیات امنیت)،
 - IR (پاسخ‌گویی به رخدادها)،

○ GRC (حاکمیت، ریسک و انطباق).

- میزان بلوغ این همکاری‌ها تعیین می‌کند خروجی تیم قرمز تا چه حد به بهبود واقعی امنیت سازمان منجر می‌شود.

الزامات قانونی و مقرراتی

- شناسایی الزامات رسمی که بر فعالیت‌های تیم قرمز اثر می‌گذارند.
- مثال‌ها: تناوب تست‌های اجباری بر اساس TIBER-EU، الزامات تطبیق با DORA یا الزامات NIS۲ در برخی صنایع.

همسویی با ریسک‌های کسب‌وکار

- اطمینان از اینکه سناریوهای تیم قرمز با مهم‌ترین دارایی‌های سازمان (Crown Jewels) و تهدیدات واقعی صنعت همخوانی دارند.
- مثال: در بانکداری تمرکز بر حملات به سامانه‌های پرداخت، یا در انرژی تمرکز بر حملات ICS/SCADA.

۴. ساختاردهی نقشه راه

نقشه راه باید به‌صورت سالانه یا بر اساس فازهای قابلیت طراحی شود:

سال ۱ – ایجاد پایه

- رسمی‌سازی چارچوب تعامل و قوانین درگیری (ROEs)
- ایجاد طرح‌های اولیه شبیه‌سازی مهاجم (مانند FIN۶ APT۲۹)
- توسعه اولین زیرساخت داخلی عملیات تیم قرمز
- طراحی الگوهای استاندارد برای گزارش دهی تعاملات

سال ۲ – بلوغ عملیاتی

- یکپارچه‌سازی با تیم‌های آبی و بنفش
- خودکارسازی بخش‌هایی از زیرساخت و اجرای TTP-ها
- ایجاد پایگاه دانش از سناریوهای قابل بازپخش
- همسویی یافته‌ها با الزامات انطباقی (مثلاً ماده ۱۲ DORA)

سال ۳ – گسترش استراتژیک

- طراحی کمپین‌های تهدید خاص صنعت

- تأثیرگذاری بر بازی‌های معماری و گزارش دهی به هیئت‌مدیره
- ایجاد مسیر آموزشی داخلی برای تربیت نقش‌های تیم قرمز
- عملیاتی سازی یافته‌های تیم قرمز در نقشه راه امنیتی سازمان

۵. ابزارهای ردیابی بلوغ

- MITRE Engage: برای نگاشت اهداف تعامل به نتایج امنیتی سازمان
- ATT&CK Navigator: برای نمایش پوشش تشخیص و تاریخچه تست‌ها
- کارت امتیاز / داشبورد امنیتی: برای کمی سازی پیشرفت در طول زمان
- Threat-Informed Defense Maturity Matrix: برای ترکیب ارزیابی استراتژیک و فنی بلوغ

۶. حاکمیت و همسویی با بودجه

نقشه راه باید:

- هر سال با CISO، واحد GRC و رهبران ریسک بازی‌ها شود
- افزایش بودجه و نیروی انسانی را بر اساس فازهای نقشه راه توجیه کند
- از شاخص‌های تیم قرمز (مثل کاهش MTTD، افزایش پوشش تشخیص) به عنوان مدرک ROI امنیتی استفاده کند
- بازتاب‌دهنده الزامات در حال تغییر تحت TIBER-EU، DORA یا ۲NIS باشد

۷. جمع‌بندی

یک نقشه راه بلوغ مبتنی بر تهدید:

- تعاملات تاکتیکی را به تحول استراتژیک تبدیل می‌کند
- سرمایه‌گذاری‌ها را با همسویی روشن با کسب‌وکار توجیه می‌کند
- یک قابلیت آفندی پایدار می‌سازد که خود را با تهدیدات و نیازهای کسب‌وکار در حال تحول وفق می‌دهد

۵,۳ - نهادهای سازی بازخورد و درس‌های آموخته‌شده

هدف

ایجاد فرآیندهای رسمی برای جمع‌آوری، مستندسازی و به کارگیری بازخورد و درس‌های آموخته‌شده از عملیات تیم قرمز، به گونه‌ای که سازمان بتواند بهبود مستمر داشته باشد و دانش امنیتی در سطح کل سازمان حفظ شود.

۱. چرا بازخورد باید نهادهای شود؟

در عملیات تیم قرمز، معمولاً بینش‌های ارزشمندی به دست می‌آید؛ اما اگر این درس‌ها به صورت ساختارمند و پس از پایان عملیات ثبت و پیگیری نشوند:

- به مرور زمان فراموش می‌شوند.
- تأثیری بر برنامه‌ریزی‌های راهبردی سازمان نمی‌گذارند.
- در تکرارهای آینده تیم قرمز یا تیم آبی دوباره کشف یا تکرار می‌شوند.

برای تقویت تاب‌آوری سازمان، باید این بازخوردها از حالت واکنشی خارج شوند و به بخشی از حافظه نهادی سازمان تبدیل شوند.

۲. ایجاد چارچوب درس‌های آموخته‌شده

برای هر عملیات تیم قرمز، یک چارچوب تکرارپذیر و ساختاریافته استفاده شود:

فاز	فعالیت‌ها
پایان عملیات (Engagement Closeout)	برگزاری جلسات مرور فنی و عملیاتی با تیم قرمز، تیم آبی و تیم سفید
بازبینی سریع (Hotwash Reviews)	دریافت فوری بازخورد درباره عملکرد ابزارها، میزان قابلیت تشخیص و فرآیندهای داخلی
تحلیل ریشه‌ای (Root Cause Analysis)	شناسایی علت‌های اصلی ضعف‌ها: مربوط به افراد، فرآیندها یا فناوری‌ها
نگاشت در سطح تکنیک (TTP-Level Mapping)	پیوند دادن موفقیت‌ها یا شکست‌ها به تکنیک‌ها و روش‌های مشخص در ATT&CK
فهرست توصیه‌ها (Recommendation Backlog)	انتقال مشکلات حل نشده به تیم مهندسی امنیت یا پیگیری‌های مدیریت ریسک

ابزارهای مشارکتی مانند Confluence، Jira، GitLab یا پورتال‌های داخلی برای ثبت و اشتراک‌گذاری این نتایج توصیه می‌شوند.

۳. دسته‌بندی بازخوردها

بازخورد و درس‌های آموخته‌شده باید در سه بُعد اصلی ثبت شوند:

- فنی/تاکتیکی:
 - محدودیت ابزارها
 - میزان موفقیت یا ناکامی بارهای مخرب (Payloads)
 - رفتار نقاط پایانی و تکنیک‌های فرار از شناسایی
- عملیاتی/فرآیندی:
 - پایداری زیرساخت فرماندهی و کنترل (C2)
 - زمان‌بندی و مدیریت عملیات
 - شفافیت قوانین درگیر شدن (ROE) و پروتکل‌های تشدید
- راهبردی/سازمانی:
 - ضعف در کتابچه‌های واکنش (Response Playbooks)
 - اختلاف درک ریسک بین تیم‌های فنی و مدیران کسب‌وکار
 - مشکلات ارتباطی بین تیم قرمز، تیم آبی و تیم سفید

۴. انتقال بازخورد به سیستم‌های سازمانی

بیشتر تیم‌های قرمز باید به سایر بخش‌های سازمان منتقل شود:

- SOC و تیم آبی: استفاده از نقاط ضعف برای آموزش تحلیلگران و بهبود محتوای شناسایی.
 - GRC/ریسک: ثبت در رجیستر ریسک‌ها و طرح‌های مدیریت ریسک.
 - مهندسی امنیت: انتقال به بک‌لاگ فنی برای رفع آسیب‌پذیری‌ها یا تقویت کنترل‌ها.
 - مدیریت ارشد: ارائه نکات کلیدی در گزارش‌های مدیریتی و هیئت‌مدیره.
- باید قابلیت ردیابی (Traceability) وجود داشته باشد؛ یعنی یافته‌های تیم قرمز به مالک ریسک، زمان‌بندی رفع و مسیرهای ممیزی متصل شوند.

۵. ابزارها و فرآیندهای نگهداری بازخورد

- پایگاه دانش تیم قرمز: ایجاد ویکی داخلی یا پلتفرم ساختار یافته برای ثبت:

مقدمه‌ای بر مدیریت عملیات تیم قرمز

- عملیات گذشته
- TTP-های مؤثر
- ضعف‌های دفاعی شناسایی شده
- روش‌های دور زدن شناسایی و راهکارهای مقابله
- سناریوهای قابل بازاجرا: بسته‌بندی زنجیره‌های حمله موفق یا کشف نشده به‌عنوان موارد آزمایشی برای تیم بنفش یا آموزش.
- مهندسی شناسایی با کنترل نسخه: یکپارچه‌سازی بهبودهای شناسایی در قالب قوانین SIEM یا مخازن YARA/Sigma با استفاده از Git.

۶. شاخص‌ها برای سنجش یادگیری نهادی

برای ارزیابی اینکه سازمان تا چه حد از عملیات تیم قرمز درس گرفته و آن را به بهبود واقعی امنیت تبدیل کرده، می‌توان از شاخص‌های زیر استفاده کرد:

درصد اجرای توصیه‌های تیم قرمز در بازه SLA

- اندازه‌گیری می‌کند چه تعداد از پیشنهادهای اصلاحی تیم قرمز در زمان توافق شده (Service Level Agreement) اجرا شده‌اند.
- اگر این عدد پایین باشد، نشان‌دهنده ضعف در پیگیری و پاسخ‌گویی سازمان است.

کاهش تکرار مسیرهای نفوذ قبلاً بهره‌بردار شده

- بررسی می‌کند آیا نقاط ضعفی که قبلاً تیم قرمز از آن‌ها استفاده کرده، دوباره در تست‌های بعدی تکرار می‌شوند یا خیر.
- کاهش این عدد یعنی سازمان از اشتباهات گذشته یاد گرفته است.

تعداد تشخیص‌های جدید یا بهبودیافته

- شمارش هشدارها، قوانین شناسایی یا ابزارهایی که در نتیجه سناریوهای تیم قرمز ایجاد یا بهبود یافته‌اند.
- این شاخص نشان می‌دهد که SOC و تیم‌های دفاعی تا چه حد از شبیه‌سازی حملات برای بهبود پایش امنیتی استفاده کرده‌اند.

مدت‌زمان به‌روزرسانی چرخه Playbook پس از هر تعامل

- یعنی فاصله زمانی بین پایان یک عملیات تیم قرمز تا زمانی که راهکارها یا رویه‌های عملیاتی (Playbook-ها) در سازمان اصلاح و به‌روز می‌شوند.

- هر چه این زمان کوتاه‌تر باشد، توانایی سازمان در یادگیری و اعمال تغییرات سریع‌تر است.

بهبود امتیاز پاسخ به سناریوها

- ارزیابی عملکرد سازمان در تمرین‌های شبیه‌سازی (Tabletop Exercises) یا بازپخش سناریوها (Replay).
- بهبود امتیازها نشان می‌دهد که تیم‌ها در مدیریت رخدادها تجربه بیشتری کسب کرده‌اند.

۷. جاسازی درس‌ها در فرهنگ‌سازمانی

- برگزاری جلسات بازنگری مشترک تیم قرمز/آبی به صورت فصلی.
- گنجاندن جمع‌بندی تیم قرمز در جلسات مرور پس از حادثه.
- انتشار مطالعات موردی ساده‌سازی شده به صورت «حمله ماه» برای کارکنان داخلی.
- استفاده از نتایج تیم قرمز در آموزش آگاهی‌بخشی امنیتی و تمرین‌های شبیه‌سازی مدیریتی.

این کار باعث می‌شود سازمان به فرهنگی برسد که یافته‌های تهاجمی (Offensive Insights) به دفاع پیشگیرانه تبدیل شوند.

۵,۴ – اعتبارسنجی برنامه و آمادگی برای ممیزی

هدف

اطمینان از اینکه عملیات تیم قرمز همواره برای ممیزی آماده هستند، مستندسازی کامل دارند و با الزامات انطباقی (Compliance) در چارچوب‌هایی مانند DORA، TIBER-EU، ISO ۲۷۰۰۱ و سایر مقررات مرتبط هماهنگ‌اند. این مستندسازی باید نشان دهد که شبیه‌سازی مهاجم به‌صورت ساختاریافته، قابل‌ردیابی و قابل دفاع انجام‌شده است.

۱. چرا تیم قرمز باید اعتبارسنجی و مستندسازی شود؟

چارچوب‌های مدرن نظارتی و ممیزی، از سازمان‌ها انتظار دارند که:

- روش‌های آزمون امنیتی قابل‌ردیابی باشند.
- شواهدی از اعتبارسنجی مستمر کنترل‌های امنیتی ارائه شود.
- نتایج آزمون‌ها بر اساس ریسک‌ها باشد.
- مستنداتی وجود داشته باشد که گزارش دهی راهبری (Governance) و انطباق (Compliance) را پشتیبانی کند.

یک برنامه تیم قرمز که به‌خوبی اداره شود باید هم به‌عنوان یک عملکرد امنیتی و هم به‌عنوان یک ابزار اعتبارسنجی کنترل‌های ریسک، قابل ممیزی باشد.

۲. اسناد کلیدی موردنیاز

هر عملیات تیم قرمز باید مجموعه‌ای از اسناد تولید کند که شفافیت عملیاتی و انطباق را تضمین کند. مهم‌ترین آن‌ها:

سند	هدف
منشور و دامنه عملیات (Engagement Charter & Scope)	تعریف اختیارات، اهداف، محدوده و ذی‌نفعان
قوانین درگیر شدن (ROE)	تعیین محدودیت‌های فنی، حقوقی و رویه‌ای
طرح شبیه‌سازی مهاجم (Adversary Emulation Plan)	توضیح مهاجم انتخاب‌شده، TTP-ها، زیرساخت و اهداف
ارزیابی ریسک یا پیش‌مجوز	پذیرش رسمی ریسک‌ها و تأثیرات احتمالی
طرح امنیت عملیاتی (OPSEC Plan)	حفاظت از زیرساخت، اقدامات ایمنی و پروتکل‌های توقف فوری (Kill-Switch)

مقدمه‌ای بر مدیریت عملیات تیم قرمز

جدول زمانی فنی/گزارش عملیات	شرح گام به گام فعالیت‌ها و نگاشت آن‌ها به چارچوب ATT&CK
گزارش یافته‌ها (Findings Report)	اولویت‌بندی یافته‌های فنی و راهبردی همراه با توصیه‌ها
جمع‌بندی پس از عملیات	درس‌های آموخته‌شده، شاخص‌های شناسایی و نتایج بهبود کنترل‌ها

این اسناد باید با کنترل نسخه مدیریت شوند و به مالک مناسب (Risk Owner یا مسئول فنی) متصل باشند.

۳. الزامات نظارتی که تیم قرمز می‌تواند پوشش دهد

چارچوب	ارتباط با تیم قرمز
TIBER-EU	نیازمند تست ساختاریافته مبتنی بر تهدید واقعی و گزارش رسمی، همراه با پیگیری تیم بنفش
DORA (ماده‌های ۱۱ و ۱۲)	الزام به آزمون‌های پیشرفته مبتنی بر تهدید و اعتبارسنجی قابلیت‌ها در سامانه‌های حیاتی و سرویس‌های شخص ثالث
ISO/IEC ۲۷۰۰۱:۲۰۲۲	نتایج تیم قرمز می‌تواند به ضمایم A.۵ (کنترل‌های سازمانی)، A.۸ (کنترل‌های فنی) و A.۱۷ (تداوم کسب و کار) کمک کند
SOC ۲ (معیارهای امنیت و دسترس‌پذیری)	پشتیبانی از اعتبارسنجی کنترل‌ها، آزمون واکنش به حادثه و شواهد تاب‌آوری
PCI DSS v۴,۰	هم‌ترازی با الزامات تست نفوذ و اعتبارسنجی کنترل‌های جبرانی

۴. آماده‌سازی برای ممیزی‌های داخلی و خارجی

برای اینکه عملیات تیم قرمز آماده ممیزی باشد:

- تمام مستندات تیم قرمز در یک مخزن قابل ممیزی (مانند Confluence، SharePoint یا پلتفرم‌های GRC) متمرکز شود.
- ارتباط شفاف بین تکنیک‌ها (TTPs) و سیستم‌ها/کنترل‌های تحت تأثیر برقرار شود.
- از ATT&CK و FEND۳D برای توضیح پوشش کنترل‌ها و راهبردهای شناسایی استفاده شود.
- برای هر یافته، یک مالک ریسک تعیین و وضعیت تا زمان رفع پیگیری شود.
- گزارش‌های مدیریتی تهیه شود که اثرات غیر فنی (کسب و کار و راهبردی) را هم توضیح دهد.

ممیزان معمولاً به دنبال قابلیت تکرار، نظارت و پاسخ‌گویی در رفع اشکالات هستند، نه صرفاً فعالیت‌های فنی.

۵. بازبینی راهبری تیم قرمز

برای اطمینان از سلامت و اعتبار برنامه تیم قرمز، باید نقاط کنترل راهبری (Governance Checkpoints) به‌صورت منظم اجرا شوند:

- مرور سالانه برنامه تیم قرمز با حضور مدیر ارشد امنیت اطلاعات (CISO)، مدیر ریسک و تیم انطباق؛
- ارائه گزارش پس از هر عملیات به هیئت‌مدیره یا کمیته ممیزی برای شفافیت و پاسخ‌گویی؛
- انتخاب عملیات بر اساس ریسک و ارائه توجیه روشن برای دامنه هر تست؛
- بازبینی ابزارها و تکنیک‌ها برای اطمینان از رعایت ملاحظات اخلاقی و قانونی.

این رویکرد باعث می‌شود که عملکرد تیم قرمز از یک فعالیت صرفاً فنی فراتر رفته و به یک قابلیت سازمانی قابل اعتماد و همسو با اهداف کسب‌وکار تبدیل شود.

۶. شواهد بهبود مستمر

باید نشان داده شود که یافته‌های تیم قرمز منجر به نتایج عملی شده‌اند:

- بهبود محتوای شناسایی و پوشش دفاعی.
- به‌روزرسانی سیاست‌های امنیتی و استانداردهای فنی.
- مستندسازی اقدامات اصلاحی با تاریخ اجرا.
- کاهش میانگین زمان شناسایی (MTTD) یا پاسخ (MTTR).
- آزمون مجدد ضعف‌های قبلی در قالب تمرین‌های تیم بنفش.

این همان چیزی است که ممیزان به دنبال آن هستند: خروجی‌های قابل اقدام، نه فقط گزارش‌ها.

۷. جعبه‌ابزار آمادگی برای پاسخ به ممیزی

برای آنکه سازمان در مواجهه با ممیزی‌های داخلی یا خارجی آماده باشد، باید مجموعه‌ای از مستندات و شواهد کلیدی از فعالیت‌های تیم قرمز به‌صورت منظم و قابل ارائه نگهداری شود:

- آخرین دو گزارش تیم قرمز
- همراه با داده‌های پالایش‌شده (Sanitized) تا اطلاعات حساس سازمان افشا نشود.
- قوانین درگیری (ROE) و فرم‌های تأییدیه

نشان‌دهنده چارچوب قانونی و فنی تست‌ها و مجوزهای رسمی پیش از اجرا.

- ثبت به‌روز ریسک‌ها (Risk Register)
شامل یافته‌های تیم قرمز و ارتباط آن‌ها با مالکان ریسک در سازمان.
 - پلی‌بوک‌ها (Playbooks) یا سناریوهای واکنش
که بر اساس نتایج تیم قرمز به‌روزرسانی شده‌اند.
 - شاخص‌ها و معیارهای پیشرفت سال‌به‌سال
مثل بهبود در زمان کشف و پاسخ (MTTD/MTTR)، کاهش تکرار ضعف‌های پیشین یا افزایش سطح پوشش تشخیص.
- نگهداری و آمادگی این اقسام به سازمان کمک می‌کند تا در برابر ممیزها نشان دهد که فرآیند تست‌های تیم قرمز قابل‌ردیابی، ساختار یافته و همراه با بهبود مستمر است.

۵,۵ – امنیت عملیاتی (OpSec) برای تیم قرمز در بلندمدت

هدف:

پیاده‌سازی رویه‌های قوی امنیت عملیاتی (Operational Security — OpSec) برای حفاظت از کمپین‌ها، زیرساخت، شناسه‌ها (identities) و ابزارهای تیم قرمز در برابر افشا، به‌طوری‌که دوام، مخفی‌کاری و یکپارچگی حرفه‌ای در طول چندین عملیات حفظ شود.

۱. نقش OpSec در تیم قرمز

تیم‌های قرمز شبیه‌سازی کننده مهاجمان واقعی هستند، اما برخلاف مهاجمان واقعی، باید موارد زیر را تضمین کنند:

- از ایجاد خسارت غیرعمدی جلوگیری کنند (به‌عنوان مثال نفوذ به داده‌های حساس یا اختلال در خدمات).
- محرمانگی کمپین‌ها را از مدافعان حفظ کنند (مگر در سناریوهایی مانند Purple Team که هماهنگی لازم است).
- زیرساخت، روش‌ها (TTPs) و ابزارها را از شناسایی، انتساب (attribution) یا استفاده مجدد غیرمجاز محافظت کنند.

OpSec مؤثر اعتبار تیم قرمز را حفظ می‌کند، حقیقی بودن تست‌ها را تضمین می‌کند و از افشای استراتژی یا ابزارها جلوگیری می‌کند.

توضیح اصطلاحات کلیدی:

OpSec (Operational Security): مجموعه تدابیر و رویه‌هایی که برای محافظت از عملیات، ابزار و اطلاعات حساس به کار می‌رود.

TTPs: تاکتیک‌ها، تکنیک‌ها و رویه‌ها (Tactics, Techniques, and Procedures) — الگوهای رفتاری مهاجمان که در شبیه‌سازی‌ها استفاده می‌شود.

Attribution (انتساب): تعیین این‌که چه کسی یا کدام حساب/زیرساخت یک فعالیت را انجام داده است.

۲. ستون‌های اصلی OpSec در تیم قرمز

شرح و نکات اجرایی	ستون (Pillar)
جداسازی شبکه و منابع، استفاده از منابع قابل دور انداختن (disposable assets)، رمزنگاری داده‌ها و فراهم‌سازی با روش‌های ناشناس ساز.	امنیت زیرساخت (Infrastructure Security)
ثبت دامنه‌ها، سرورها (VPS) و آدرس‌های ایمیل با هویت‌های غیر مرتبط (persona) تا ردگیری به هویت واقعی سخت شود.	کنترل هویت و انتساب (Identity & Attribution Control)
حذف متادیتا، خودداری از استفاده مجدد بدون بازسازی، پنهان‌سازی شاخص‌ها (IOC) و آزمایش توانمندی دور زدن EDR قبل از اجرا.	بهداشت ابزار و پیلودها (Tool & Payload Hygiene)
تصادفی سازی فواصل بازگشت (callback)، تقلید پروتکل‌های مشروع و در صورت نیاز استفاده از مکانیزم‌هایی مانند domain fronting یا Cloud redirectors.	کنترل ترافیک و رفتار beaconing (Traffic and Beaconing Discipline)
لاگ‌گیری امن از اقدامات، جلوگیری از افشای تصادفی شواهد و پاک‌سازی یا پالایش (sanitize) اقلام پس از اتمام عملیات.	کنترل شواهد عملیات (Engagement Artifact Control)

توضیح: «Disposable assets» یعنی منابعی که پس از استفاده قابل نابودی یا کنار گذاشتن هستند تا ردیابی طولانی مدت ایجاد نشود.

۳. طراحی زیرساخت و ایزولاسیون

برای ایمنی، محیط‌های تیم قرمز باید با اصول ایزولاسیون طراحی شوند:

- استفاده از زیرساخت فرماندهی و کنترل (C2 Command and Control —) با طبقه‌بندی (مثلاً redirectors، سرورهای staging، listeners مانند Cobalt Strike یا Sliver).
- استقرار زیرساخت در ارائه‌دهندگانی که ریسک انتساب را کاهش می‌دهند (اجتناب از IP-ها یا اطلاعات صورتحساب متصل به سازمان هدف).
- مسیریابی ترافیک از طریق زنجیره VPN یا واسطه‌های ابری (cloud relays) برای پنهان کردن منبع واقعی.
- تناوب و دوره‌ای تغییر دادن دامنه‌ها و گواهی‌نامه‌ها (certificates).

زیرساخت‌ها باید قابل دورریز، رمزگذاری شده در حالت سکون (encrypted at rest) و در برابر افشای تصادفی مقاوم باشند.

۴. حفاظت از payload-ها و ایمپلنت‌ها (Implants)

دستورالعمل‌های OpSec برای مدیریت payload-ها:

- رمزگذاری payload-ها (مثلاً با AES یا روش‌های XOR) و خودداری از قرار دادن شاخص‌های متنی واضح در آن‌ها.
 - استفاده از تکنیک‌هایی مانند تحریف در زمان اجرا (runtime obfuscation)، اجرای در حافظه (in-memory execution) و مکانیزم‌های اجتناب از sandbox.
 - آزمایش همه باینری‌ها در محیط‌های آزمایشی با مجموعه‌های EDR/XDR جاری قبل از استفاده در عرصه واقعی.
 - حذف رشته‌ها و نمادها (strip strings/symbols) و کامپایل با متادیتای پاک‌شده (به‌عنوان مثال روش‌هایی نظیر strip یا تکنیک‌های مشابه).
- توجه: هر payload بین مشتریان یا کمپین‌ها نباید بدون تغییر و امضای مجدد دوباره استفاده شود تا از انتساب یا تشخیص جلوگیری شود.

توضیح برخی اصطلاحات فنی:

EDR/XDR: محصولاتی که برای کشف و پاسخ‌دهی به تهدیدات نقاط پایانی (Endpoint Detection and Response) یا گسترده‌تر (Extended Detection and Response) به کار می‌روند.

IOC (Indicator of Compromise): شواهدی که نشان می‌دهد یک رخداد مخرب رخ داده است (مثلاً دامنه‌های توزیع‌شده، هش فایل‌ها).

۵. مدیریت هویت و ساختن هویت پوششی (Persona)

راهنمایی‌های هویتی:

- ایجاد هویت‌های یک‌بارمصرف (throwaway personas) برای کمپین‌های فیشینگ، جمع‌آوری اطلاعات اعتباری یا مهندسی اجتماعی.
- ثبت دامنه‌ها از طریق ثبت‌کننده‌های دارای قابلیت حفظ حریم خصوصی، با استفاده از موضوعات بی‌طرف و غیر مشکوک (برای مثال: منابع انسانی، امور مالی یا لجستیک).
- استفاده از حساب‌های موقت (burner accounts) و محیط‌های ایزوله (containers) برای همه دسترسی‌ها و فعالیت‌های وب.
- پایش مداوم برای شناسایی آشکار شدن توسط فروشندگان CTI یا اسکنرهای متن‌باز.

نکته کلیدی: هر هویت باید به صورت کاملاً جداگانه و مختص به هر عملیات ساخته و مدیریت شود تا از ارتباط دادن چند عملیات مختلف به یکدیگر (Cross-Engagement Attribution) جلوگیری گردد.

توضیح برخی اصطلاحات فنی:

Persona: یک هویت ساختگی یا پوششی که برای تعامل در فضای مجازی استفاده می‌شود.

CTI (Cyber Threat Intelligence): اطلاعات تهدید که ممکن است عملیات تیم قرمز را کشف کند.

۶. OpSec تدافعی: جلوگیری از شناسایی زود هنگام

برای کاهش احتمال شناسایی اولیه:

- از اسکن کردن مستقیم با زیرساخت تیم قرمز خودداری کنید؛ از نودهای جداگانه برای شناسایی (recon nodes) یا داده‌های شخص ثالث استفاده کنید.
- دسترسی اولیه را با دقت مرحله‌بندی کنید تا تعداد لاگ‌ها، هشدارها و رفتارهای غیرعادی (behavioral anomalies) به حداقل برسد؛ به عبارت دیگر، شبیه‌سازی ورود باید به گونه‌ای انجام شود که کمتر از رفتار طبیعی سازمان متفاوت باشد.
- تلمتری (telemetry) غیرضروری ابزارها را غیرفعال کنید. به عنوان مثال، از ارسال اطلاعاتی که پیکربندی C2 (Command-and-Control) را در memory dumps نشان می‌دهد، خودداری کنید تا از نشت تصادفی اطلاعات ساختار ارتباطی جلوگیری شود.
- در شبیه‌سازی فرضی نفوذ (assumed breach) واکنش‌های تیم آبی را بی‌صدا پایش کنید تا اثرگذاری شبیه‌سازی حفظ شود.

امنیت عملیاتی (OpSec) فقط مربوط به عوامل بیرونی نیست؛ بلکه به این معناست که تیم قرمز باید درون محیط هدف طوری رفتار کند که با فعالیت‌های عادی سازمان یکی به نظر برسد و نشانه‌ها و رفتارهای غیرمعمول (نویز رفتاری) را به حداقل برساند

۷. پاک‌سازی پس از پایان عملیات (Post-Engagement Sanitization)

اقدامات پس از عملیات باید شامل موارد زیر باشد:

- نابودی یا بازسازی (reimage) زیرساخت‌های C2.
- حذف و از بین بردن (shred) پیلودها، لاگ‌ها و متادیتا.
- آرشو سازی امن گزارش‌ها و اسکرین‌شات‌ها در مخزن داخلی با کنترل دسترسی.

- پس از پایان هر عملیات، باید با استفاده از یک چک‌لیست داخلی بازبینی پس از عملیات، بررسی شود که همه اصول امنیت عملیاتی (OpSec) مانند پاک‌سازی زیرساخت، حذف شواهد و محافظت از ابزارها به‌درستی رعایت شده‌اند.

همه آثار مربوط به عملیات تیم قرمز باید حتی پس از اتمام تست به‌عنوان اطلاعات حساس در نظر گرفته شوند.

۸. ابزارها و تکنیک‌هایی که از OpSec پشتیبانی می‌کنند

نمونه ابزارها و کاربردهای آن‌ها (ذکر نام ابزار صرفاً به‌منظور مرجع است):

- ابزارهای حفاظت از پیلود و مخفی سازی (مثلاً Invoke-PSObfuscation، ConfuserEx، ScareCrow).
- ابزارهای IAC (Infrastructure as Code) مانند Terraform یا Ansible برای ایجاد منابع قابل دورریز و مدیریت قابل بازتولید زیرساخت.
- پلتفرم‌های C۲ انعطاف‌پذیر مانند Sliver یا Mythic که قابلیت‌های ارتباطی رمزگذاری شده و پروفایل‌های قابل تنظیم دارند.
- Burp Collaborator یا CanaryTokens برای آزمایش مرزهای OpSec و تشخیص لو رفتن نشانه‌ها.
- چارچوب‌هایی مانند Atomic Red Team یا Caldera در محیط‌های ایزوله برای تحلیل ریسک شناسایی و تست تأثیر اصلاحات.

توضیح: ابزارهای ذکرشده صرفاً به‌عنوان نمونه ارائه‌شده‌اند؛ انتخاب و به‌کارگیری هر ابزار باید با رعایت ملاحظات اخلاقی، قوانین جاری و سیاست‌ها و چارچوب‌های سازمانی باشد.

خلاصه و نتیجه‌گیری

موفقیت و امنیت یک تیم قرمز کاملاً به میزان پایداری آن به اصول امنیت عملیاتی (OpSec) وابسته است. هرچه عملیات پیچیده‌تر و تحت مقررات بیشتری قرار گیرند، توانایی تیم برای مخفی ماندن، کنترل‌شده عمل کردن و حرفه‌ای بودن نه یک انتخاب، بلکه یک ضرورت اساسی و زیربنایی خواهد بود. OpSec خوب به سازمان اجازه می‌دهد تست‌های واقع‌گرایانه انجام دهد، ابزارها را محافظت کند و درعین حال از آسیب رساندن یا افشای تصادفی جلوگیری نماید.

۵.۶ - ارزیابی نهایی: ارائه استراتژی یا دفاع از سناریو

هدف:

مهارت و شایستگی شرکت‌کنندگان از طریق ارائه ساختارمند یا دفاع از یک برنامه کامل کمپین تیم قرمز سنجیده می‌شود، به گونه‌ای که همسویی استراتژیک، عمق عملیاتی و آمادگی برای رعایت الزامات قانونی و مقرراتی تحت بازبینی شبیه‌سازی شده ذی‌نفعان به نمایش گذاشته شود.

۱. هدف از ارزیابی نهایی

ارزیابی نهایی تعاملات واقعی با ذی‌نفعان را شبیه‌سازی می‌کند، جایی که تیم قرمز باید:

- رویکرد و محدوده فعالیت خود را توجیه کند
- برنامه را با نیازهای کسب‌وکار و الزامات قانونی همسو کند
- از روش‌شناسی خود را از منظر ریسک، رعایت مقررات و جنبه‌های عملیاتی دفاع کند.

این ارزیابی تنها یک آزمون فنی نیست؛ بلکه نمایش بلوغ، شفافیت و تفکر استراتژیک است.

۲. قالب‌های ارزیابی

توضیح	قالب
شرکت‌کنندگان یک جلسه ساختارمند از برنامه کمپین تیم قرمز خود به پنلی که نقش مدیران اجرایی، GRC و رهبری فنی را شبیه‌سازی می‌کند، ارائه می‌دهند.	ارائه (Presentation)
شرکت‌کنندگان به پرسش‌ها و چالش‌های شبیه‌سازی شده ذی‌نفعان بر اساس برنامه خود پاسخ می‌دهند. این بخش می‌تواند به صورت زنده یا کتبی انجام شود.	دفاع از سناریو (Scenario Defense)

هدف: اعتبارسنجی آمادگی، منطق و مسئولیت‌پذیری تیم قرمز.

۳. معیارهای ارزیابی

برنامه کمپین یا ارائه باید موارد زیر را پوشش دهد:

- مدل تهدید و انتخاب TTP
 - استفاده از مهاجم مرتبط (مثلاً FIN۶، APT۲۹)
 - تطابق با تکنیک‌های ATT&CK و دارایی‌های حیاتی سازمان (Crown Jewels)
- برنامه‌ریزی عملیاتی و OpSec

- طراحی زیرساخت، ابزارها و اقدامات ایمنی
- کنترل‌های OpSec، هماهنگی و محدودسازی خطر
- هماهنگی با کسب‌وکار و ریسک
 - توجیه محدوده فعالیت
 - ارتباط با اثرات کسب‌وکار و الزامات قانونی و مقرراتی (مثلاً ماده ۱۲ DORA)
- قوانین اجرایی و حاکمیت
 - محدودیت‌های قانونی، اخلاقی و فنی
 - مکانیزم‌های تأیید و نظارت
- برنامه پس از اجرا (Post-Engagement)
 - ساختار گزارش دهی، Purple Teaming، اصلاحات و یادگیری مستمر
- شاخص‌ها و ارزش مستمر
 - کلیدهای شاخص عملکرد برای تشخیص، زمان حضور تهدید (Dwell Time)، زمان اصلاح و بلوغ برنامه

۴. نقش‌های شبیه‌سازی‌شده ذی‌نفعان (اختیاری برای ارائه زنده)

نقش	حوزه تمرکز
مدیر اجرایی (CISO, COO)	ریسک استراتژیک، اثر بر برند، ارزش کسب‌وکار
مسئول هماهنگی	آمادگی برای ممیزی، هماهنگی با مقررات
معمار امنیت	واقع‌گرایی فنی، مناسب بودن ابزارها
مدیر SOC / تیم آبی	اثرگذاری بر تشخیص، بازخورد و بهبود پوشش
جلسات بازخورد شبیه‌سازی‌شده می‌توانند برای به چالش کشیدن فرضیات و تشویق به اصلاح برنامه برگزار شوند.	

۵. روش‌های ارائه و تحویل خروجی‌ها

شرکت‌کنندگان می‌توانند یکی از موارد زیر را ارائه یا ارسال کنند:

- مستند عملیات تیم قرمز (۱۰-۱۵ صفحه یا اسلایدهای ساختارمند)
- ارائه شفاهی یا ضبط‌شده برنامه عملیاتی تیم قرمز (۱۰-۱۵ دقیقه)
- جلسه پرسش و پاسخ دفاع از سناریو با مدرس یا هم‌تایان

معیار ارزیابی: کیفیت محتوا، آگاهی از ریسک، واقع‌گرایی و وضوح ارتباطات.

۶. بازخورد و امتیازدهی

رویکرد ارزیابی باید شامل:

- جامعیت برنامه
- واقع‌گرایی تهدید و صحت شبیه‌سازی
- شفافیت اهداف، محدوده و نتایج
- عمق پیاده‌سازی OpSec و حاکمیت
- کاربرد عملی محتوای دوره
- تطابق استراتژیک با ریسک سازمان

مدرسین می‌توانند بازخورد کتبی یا شفاهی برای توسعه نهایی ارائه دهند.

۷. نتیجه

پس از تکمیل موفقیت‌آمیز، شرکت‌کنندگان باید نشان دهند:

- توانایی طراحی و توجیه عملیات کامل تیم قرمز
- آمادگی برای هدایت یا پشتیبانی از عملیات در محیط‌های پیچیده و تحت مقررات
- بلوغ در ترجمه توانمندی‌های فنی به نتایج امنیتی مرتبط با کسب‌وکار

این مرحله نشان‌دهنده اوایل ورود از دانشجوی دوره به نقش عملیاتی حرفه‌ای است و نقطه اوج دوره محسوب می‌شود.

نتیجه‌گیری

برنامه‌ریزی، اجرا و هماهنگی عملیات تهاجمی با تمرکز بر نتایج واقعی

این کتاب خوانندگان را با تمام مراحل عملیات پیشرفته تیم قرمز آشنا کرده است، از برنامه‌ریزی استراتژیک و طراحی زیرساخت گرفته تا اجرای فنی، رعایت الزامات قانونی و تبدیل نتایج پس از عملیات به اقدامات عملی.

با گذر از شش ماژول پیشرفته، یادگیرندگان توانسته‌اند مهارت‌های زیر را توسعه دهند:

- طراحی و مدیریت کمپین‌های تیم قرمز مبتنی بر تهدید که مهاجمان واقعی را با استفاده از چارچوب MITRE ATT&CK و پروفایل‌های تهدید مرتبط با بخش سازمان شبیه‌سازی می‌کنند.
- ادغام نتایج تیم قرمز در برنامه‌های امنیتی سازمان، به گونه‌ای که بر وضعیت ریسک، مهندسی تشخیص و برنامه‌ریزی تاب‌آوری تأثیرگذار باشد.
- عملکرد ایمن و مؤثر در محیط‌های هیبریدی با بهره‌گیری از تکنیک‌های شبیه‌سازی بومی ابری و اصول منظم OpSec.
- هماهنگی فعالیت‌های تیم قرمز با الزامات قانونی و مقرراتی، از جمله DORA، TIBER-EU و چارچوب‌های ISO و تبدیل آزمایش‌های فنی به فرایندی قابل دفاع و ممیزی.
- ساخت و ارائه استراتژی‌های جامع تیم قرمز که بلوغ در انتقال ریسک، برنامه‌ریزی عملیات و دفاع از روش‌شناسی در شرایط بررسی و ارزیابی را نشان دهد.

تیم قرمز دیگر صرفاً یک تمرین فنی نیست؛ بلکه یک انضباط استراتژیک است که از دفاع پیشگیرانه، تداوم کسب‌وکار و اطمینان قانونی پشتیبانی می‌کند. با بازگشت به نقش‌های سازمانی خود، این کتاب نه تنها دانش تاکتیکی، بلکه ذهنیت استراتژیک لازم برای گسترش و حفظ امنیت تهاجمی به‌عنوان یک بخش اصلی از برنامه‌های مدرن امنیت سایبری را در اختیار شما قرار می‌دهد.

ارزیابی نهایی نشان‌دهنده پایان مسیر نیست، بلکه آغاز نقش شما به‌عنوان تسهیل‌کننده تاب‌آوری است — یک حرفه‌ای که می‌تواند با دقت و هدفمند، وضعیت امنیتی را شبیه‌سازی، تأثیرگذاری و توسعه دهد.